



File No.: EXP202310012

RESOLUTION FOR TERMINATION OF THE PROCEDURE BY RECOGNITION OF RESPONSIBILITY AND VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On December 20, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against GRUPO ESPAÑOL DE TRABAJO EN ENFERMEDAD DE CHRON Y COLITIS ULCEROSA (GETECCU) (hereinafter, GETECCU), through the agreement transcribed below:

<<

File No.: EXP202310012

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following

Content

FACTS.....	3
FIRST: On June 19, 2023, the GRUPO ESPAÑOL DE TRABAJO EN ENFERMEDAD DE CHRON Y COLITIS ULCEROSA (GETECCU), with NIF G07762669 (hereinafter, GETECCU) notified this Agency of a personal data breach.....	3
SECOND: On July 5, 2023, a notification of a personal data breach was received from ***CENTRO.54 (hereinafter, ***CENTRO.54), with the following information:.....	9
THIRD: On July 4, 2023, the Catalan Data Protection Authority (APDCAT) contacted this Agency due to having received several notifications of breaches from Catalan public hospitals within its jurisdiction that identify GETECCU as the data processor and ***EMPRESA.1 as the sub-processor. APDCAT inquired whether GETECCU had notified the breach to the AEPD and with what data protection role it identified itself to determine who would be responsible for the obligation to communicate to the affected parties in accordance with Article 34 of the GDPR if necessary.....	11
FOURTH: As a consequence of the known facts, on July 13, 2023, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate for Data Inspection (SGID) to initiate the preliminary investigation actions referred to in Article 67 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD).....	13
FIFTH: On August 9, 2023, a notification of a personal data breach was received from ***CENTRO.55, with, among other information:.....	14
SIXTH: On August 10, 2023, a notification of a personal data breach was received from ***CENTRO.1 with, among other relevant content:.....	14
SEVENTH: On August 17, 2023, a notification of a personal data breach was received from ***CENTRO.53 with, among other relevant information:.....	15
EIGHTH: On August 25, 2023, a notification of a personal data breach was received from ***CENTRO.2 with, among other relevant information:.....	15
NINTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VIII of the LOPDGDD.....	16
1. Regarding the results of the investigation actions at ***CENTRO.54 (hereinafter	

***CENTRO.54):.....	16
2. Regarding the results of the investigation actions at ***CENTRO.3 (hereinafter, ***CENTRO.3):.....	20
3. Regarding the results of the investigation actions at ***CENTRO.4 (hereinafter ***CENTRO.4):.....	21
4. Regarding the results of the investigation actions at GRUPO ESPAÑOL DE TRABAJO EN ENFERMEDAD DE CHRON Y COLITIS ULCEROSA (hereinafter, GETECCU):.....	23
5. Regarding the results of the investigation actions at ***CENTRO.50:.....	47
6. Regarding the results of the investigation actions at ***CENTRO.51:.....	51
7. Internet investigation:.....	52
TENTH: According to the report collected from the AXESOR tool on December 15, 2024, the entity GETECCU is an association with a sales volume of (...) euros.....	56

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/77

LEGAL GROUNDS.....	56
I Competence.....	56
II Procedure.....	56
III Preliminary Issues.....	57
Processing of personal data.....	57
Data controller.....	58
IV Breach of obligation. Integrity and confidentiality.....	74
Loss of confidentiality of personal data.....	75
Affected personal data.....	75
Chronology of events and technical or organizational measures.....	76
V Qualification of the infringement of Article 5.1.f) of the GDPR and classification for prescription purposes.....	81
VI Proposal for sanction for the infringement of Article 5.1.f) of the GDPR.....	82
VII Breach of obligation. Data processor.....	84
VIII Qualification of the infringement of Article 28 of the GDPR and classification for prescription purposes.....	88
IX Proposal for sanction.....	88
X Corrective measures.....	90
Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,.....	91
IT IS AGREED:.....	91

FACTS

FIRST: On June 19, 2023, the SPANISH WORKING GROUP ON CHRON'S DISEASE AND ULCERATIVE COLITIS (GETECCU), with NIF G07762669 (hereinafter, GETECCU) notified this Agency of a personal data breach.

This notification informed of the following:

- The incident was intentional, aimed at harming the data controller/processor or the affected individuals.
- The origin of the incident was: External: Others, unrelated to the data controller and processor.
- What may have occurred?: Cyber incident: Unauthorized access to data in information system (corporate or internet service).

- As a consequence of the incident, the following was affected: Confidentiality.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/77

- Please provide a brief description of what occurred. "Unauthorized access to files in the secondary storage system with deletion and possible download of the same."

- Types of affected data: (...)

- The affected individuals have the following profiles: (...)

- In total, how many individuals have had their data affected by the personal data breach? (...)

- Date of detection of the breach, understood as the date on which the controller is certain that personal data has been affected: 06/16/2023.

- Date of commencement of the breach: 06/14/2023.

- Security measures prior to the breach: (...)

- GETECCU is identified as the data controller and ***COMPANY.1 as the data processor involved in the breach.

On July 11, 2023, GETECCU submitted to this Agency a written extension of the notification of this breach, in which the information initially provided remained intact, except for:

- To what extent could the identified consequences affect individuals? Individuals will not be affected or may encounter very limited and reversible inconveniences that they will overcome without any problem (time to re-enter information, inconveniences, irritations, etc.).

- As of this notification date, are you aware that any of the identified damages have materialized, to the degree indicated in the previous question? No.

- How do you assess the probability of the aforementioned damage materializing on the affected individuals with the indicated severity? Unlikely.

- Types of affected data: (...)

- In total, how many individuals have had their data affected by the personal data breach? (...)

- Have you adopted new security measures after the incident that could have prevented the breach? Yes.

- Please mark exclusively the new security measures and those that have been updated (...).

- Indicate the date on which the breach was considered resolved: 07/10/2023.

- Has the breach been communicated to the affected individuals under the previously described conditions? They will not be informed.

- The affected individuals will not be informed because: Communication entails an excessive effort.

Along with this second notification, the following is provided:

- Expert report on the breach, dated July 5, 2023, prepared by ***ORGANISM.1; this report includes the following statements made by the IT expert:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/77

"Technical recommendations that would improve the client's platform:

(...)

"In the course of the work and drafting of this expert report, ***COMPANY.1 has implemented various improvements to its procedures, which I outline below:

(...)

"Additionally, I have been able to verify the planning of technical improvement measures that are underway or will begin shortly:

(...)

The expert report concludes with the following text:

(...)

SECOND: On July 5, 2023, a notification of a personal data breach was received from ***CENTER.54 (hereinafter, ***CENTER.54), with the following information:

- The incident was Intentional, to harm the responsible party / manager or the affected individuals
- The origin of the incident was: External: Others, unrelated to the responsible party and manager of the processing
- What may have occurred?: Cyber incident: Unauthorized access to data in information system (corporate or internet service)
- As a consequence of the incident, the following has been affected: Confidentiality
- Please provide a brief description of what occurred. "We are evaluating the security breach that has been reported to us by GETECCU (Spanish Working Group on Crohn's Disease and Ulcerative Colitis), responsible for the processing of project ***PROJECT.1 through its contracted company ***COMPANY.1, in part of the infrastructure managed by them, which they indicate affects personal and clinical data of (...) from the participating hospitals in project ***PROJECT.1, including the University Hospital of Navarra. The breach has already been reported by GETECCU to the AEPD, and its registration number is ***REFERENCE.1. We refer to the data indicated in that registration. The overall scope appears to be about (...) (...) at the state level and about (...) in Navarra. They indicate that they have already notified judicial and police authorities. They have notified us that they are working on updating the technical and organizational measures of their organization within the framework of project ***PROJECT.1. Furthermore, in the case of ***CENTER.54, we are gathering information to determine the scope and impact on our (...) data and evaluating and expanding the organizational measures of our organization."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/77

- Types of affected data: Basic data (e.g., name, surname, date of birth), Contact data, Health data (other health data)
- The affected individuals have the following profiles: (...)
- In total, how many individuals have had their data affected by the personal data breach? (...)
- Indicate the date of detection of the breach, understood as the date on which the responsible party is certain that personal data has been affected 04/07/2023
- Indicate the date of the start of the breach 14/06/2023
- Security measures before the breach: (...)
- ***CENTER.54 is identified as the responsible party for the processing and GETECCU as the processor involved in the breach

On August 9, 2023, a document was received by this Agency containing, among other things, the following content:

"The company GETECCU has already made the definitive and conclusive communication of the information process regarding the security breach to the AEPD, in which they attach the final expert report prepared for ***COMPANY.1, which includes the causes and the measures implemented, with the aim of improving the platform and preventing future attacks that compromise security.

GETECCU, after analyzing and assessing the level of risk, concluding that communication to the (...)

affected would represent a disproportionate effort, and in compliance with Article 34.d of Regulation (EU) 2016/679, has decided to adopt the following communications:

- Communication of the breach to the hospital centers, Principal Investigator, and DPO.
- Communication of the (...) affected to those Hospital Centers that request it.
- Communication of the breach on the website <https://geteccu.org>

From the Security Section of ***CENTER.54, we understand that GETECCU has complied with the communication obligations to the AEPD and to the (...) affected, and we do not have additional information to contribute to the case.”

On August 10, 2023, an extension of information regarding the breach previously notified by ***CENTER.54 was received by this Agency, in which the information initially provided remained intact, except for (among other things):

- What may have occurred? You may select multiple options: Loss of confidentiality of data affected by professional secrecy, Loss of control over their personal data
- To what extent could the identified consequences affect individuals? Individuals may encounter significant inconveniences, producing limited harm, which they may overcome despite some difficulties (additional costs, denial of access to commercial services, fear, lack of understanding, stress, minor physical ailments, etc.)
- As of this notification date, are you aware that any of the identified harms have materialized, to the extent indicated in the previous question? No

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/77

- How do you assess the likelihood of the aforementioned harm materializing on the affected individuals with the indicated severity? Low
- Please provide a brief description of what occurred. “This notification is supplementary and finalizing to the initial one. ***CENTRO.54, as the data controller, has no additional information that complements what has been presented by the data processing company.”
- In total, how many individuals have had their data affected by the personal data breach? (...)
- Indicate the date on which the breach was resolved: 11/07/2023
- Has the breach been communicated to the affected individuals under the previously described conditions? Yes
- Date of notification: 11/07/2023
- Number of individuals notified: (...)
- Means by which the notification was made: Public statement or publication on corporate website
- ***CENTRO.54 is identified as the data controller and ***EMPRESA.1 as the data processor involved in the breach.

THIRD: On July 4, 2023, the Catalan Data Protection Authority (APDCAT) contacted this Agency due to having received several notifications of breaches from Catalan public hospitals within its jurisdiction that identify GETECCU as the data processor and ***EMPRESA.1 as the sub-processor involved in the breach. APDCAT inquired whether GETECCU had notified the breach to the AEPD and with what data protection role it identified itself to determine who would be responsible for the obligation to communicate to the affected individuals in accordance with Article 34 of the GDPR if necessary. APDCAT sent this Agency via email documents provided by the hospitals that had notified the breach, which summarized that the breach would have affected the so-called ***PROYECTO.1). A document titled “PROJECT ***PROYECTO.1” was attached, containing, among other things, the following content:

“The overall objective of the ***PROYECTO.1 project is the creation of an infrastructure and the necessary operational procedures for the continued development of multicenter collaborative studies regarding the factors involved in the etiology and pathophysiology of inflammatory bowel disease, including genetic and environmental factors, and epidemiological studies.”

“Each center will complete the forms that include all the clinical information of the (...) that is

considered relevant for the development of the studies. This information will be updated periodically by the researchers following the (...)."

"In order to facilitate the collection of clinical and genetic information and to protect the privacy of the (...), the information will be collected under identification codes. The identification codes will be generated automatically by the database program. Blood/DNA samples will be marked with the specific code of the ***PROYECTO.1 project.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/77

The clinical information of each patient must contain a record with the complete identification data of the patient, which will be linked to a code of the ***PROYECTO.1 project. Access to the relationship between the identification data and the code of the ***PROYECTO.1 project will only be accessible to the responsible physician of the patient who generated the information, so that they can identify the patient and communicate the results if deemed necessary for any reason, including the patient's wishes and the best treatment.

Researchers will only have access to the codes with their corresponding associated clinical information, and to the coded DNA samples in the case of genetic studies."

"The clinical information of all the (...) will be collected in a common database of the ***PROYECTO.1 project. The clinical information collected in the ***PROYECTO.1 project includes patient identification data, characteristics of their inflammatory bowel disease, examinations for the early detection of neoplastic lesions, treatments received, responses to them, and associated adverse effects, outpatient visits, hospitalizations, surgical operations, and complications thereof, risk factors for the development of the disease, including family history, associated comorbidities, and information about descendants. Participating researchers will have full access to the information generated at the center, including the identification data of the (...).

Researchers responsible for a specific study will have access to the information of the (...) included in the particular study contained in the general database and appropriately anonymized, in which cases will only be identified by the code ***PROYECTO.1."

"The ***PROYECTO.1 project is established around the Spanish Working Group on Crohn's Disease and Ulcerative Colitis (GETECCU), which will appoint the committee responsible for the ***PROYECTO.1 project and will be composed of an odd number of members, which at the discretion of GETECCU will be set at 5 or 7.

The owner, responsible for the database and data processing, is GETECCU.

GETECCU will act as the entity before which the rights of opposition, access, rectification, and cancellation can be exercised.

The database was registered with the data protection agency in 2006, and the registration was updated in 2012 to comply with current law.

The location of the server where the clinical information is stored will be the headquarters of ***EMPRESA.2, (...).

The entity responsible for the processing of data and samples will be GETECCU."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/77

On July 7, 2023, this Agency sent an email to GETECCU requesting additional information beyond that provided in the initial notification. On July 11, 2023, a response email was received from GETECCU providing the following relevant information:

- Regarding the affected data, they stated:

"These are CSV files with structured data. The personal data affected are: (...)

“As for the database ***PROJECT.1, affected by the Cyberattack, GETECCU is the data controller and ***COMPANY.1, as the technological provider, is the data processor.”

“For all of this, regarding communication to the affected parties, the following has been agreed:

- Communication of the breach to the Hospital Centers.

The breach has already been communicated to all hospital centers involved in the ***PROJECT.1, whether their (...) have been affected or not. In this way, we hold meetings with the DPOs of each Hospital, providing timely updates on the evolution of the breach and the measures implemented to date. We will continue with the information and sending of the audit and the measures definitively implemented.

- Communication of the (...) affected to those Hospital Centers that request it.

- Communication of the breach on the website <https://geteccu.org> (sic)

- They attached a PDF file with the communication of the breach that GETECCU made to the medical researchers belonging to the affected hospital centers (on June 22, 2023, and July 3, 2023). The following statement stands out from its content:

“We remind you that, in accordance with Article 33, paragraph 1, of the GDPR, your center, as the data controller/joint controller, must inform the competent supervisory authority of the data breach (no later than 72 hours after becoming aware of it), as there is a potential risk to the rights and freedoms of natural persons.”

- They attached an Excel file that includes an analysis of the risk level of the breach, providing the following relevant data:

- Volume of affected individuals: (...)

- Type of data: Sensitive.

- Impact: Significant inconveniences.

- Total Risk: 32 (HIGH).

“As a consequence of the result of the risk calculator, we consider that individual communication to the patient is not necessary, taking into account that the number of affected individuals and the communication data with them would represent a disproportionate effort.”

- They attached an Excel file with the list of hospitals and the volume of affected individuals.

FOURTH: As a consequence of the known facts, on July 13, 2023, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate for Data Inspection (SGID) to initiate the preliminary investigation actions referred to in Article 67 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD).

FIFTH: On August 9, 2023, a notification of a personal data breach was received from ***CENTER.55, with, among other information, the following:

- Provide a brief description of what happened. “This notification is a continuation of the communication submitted by GETECCU on 06/19/2023, which we consider reproduced. Unauthorized access to files from the secondary storage system, with deletion and possible download of the same.”

- Types of affected data: (...)

- The affected individuals have the following profiles: (...)

- In total, how many individuals have had their data affected by the personal data breach? (...)

- Indicate the date of detection of the breach, understood as the date on which the controller is certain that personal data has been affected

10/07/2023

- ***CENTER.55 is identified as the data controller and GETECCU as the data processor involved in the breach.

SIXTH: On August 10, 2023, a notification of a personal data breach was received from ***CENTER.1 with, among other relevant content:

- Provide a brief description of what happened. “This notification is a continuation of the communication submitted by GETECCU on 06/19/2023, which we consider reproduced. Unauthorized access to files from the secondary storage system, with deletion and possible download of the same.”

- Types of affected data: (...)

- The affected individuals have the following profiles: (...)

- In total, how many individuals have had their data affected by the personal data breach? (...)

- Indicate the date of detection of the breach, understood as the date on which the controller is certain that personal data has been affected

08/08/2023

- ***CENTER.1 is identified as the data controller and GETECCU as the data processor involved in the breach.

On September 6, 2023, an extension of information regarding the breach previously notified by ***CENTER.1 was received at this Agency, in which the initially provided information remained intact, except for (among other):

- In total, how many individuals have had their data affected by the personal data breach? (...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/77

- Has the breach been communicated to the affected individuals under the previously described conditions? Yes

- Date of notification: 06/09/2023

- Number of individuals notified (...)

- Means by which notification was made: Communication directed personally to each affected individual (postal, email, SMS or similar) with delivery and read receipt guarantee, Public statement or publication on corporate website

SEVENTH: On August 17, 2023, notification of a personal data breach was received from ***CENTRO.53 with, among other relevant information, the following:

- Provide a brief description of what occurred. "This notification is a continuation of the communication submitted by GETECCU on 19/06/2023, which we consider reproduced. Unauthorized access to files from the secondary storage system, with deletion and possible download of the same."

- Types of affected data: (...)

- The affected individuals have the following profiles: (...)

- In total, how many individuals have had their data affected by the personal data breach? (...)

- Indicate the date of detection of the breach, understood as the date on which the responsible party is certain that personal data has been affected: 10/07/2023

- Has the breach been communicated to the affected individuals under the previously described conditions? No, but they will be informed

- At the latest, the affected individuals will be informed by the following date: 18/08/2023

- Means by which notification will be made: Public statement or publication on corporate website

- ***CENTRO.53 is identified as the data controller and GETECCU as the data processor involved in the breach

EIGHTH: On August 25, 2023, notification of a personal data breach was received from ***CENTRO.2 with, among other relevant information, the following:

- Provide a brief description of what occurred. "Detection of a security breach related to the data processor ***EMPRESA.1, of Project ***PROYECTO.1, of the Spanish Working Group on Crohn's Disease and Ulcerative Colitis GETECCU that affects the information provided to the project by the Hospital Universitario Río Hortega (HURH) of Valladolid."

- Types of affected data: Health (other health data)

- The affected individuals have the following profiles: (...)

- In total, how many individuals have had their data affected by the personal data breach? (...)

- Indicate the date of detection of the breach, understood as the date on which the responsible party is certain that personal data has been affected: 14/06/2023

- Has the breach been communicated to the affected individuals under the previously described conditions? No, but they will be informed

- At the latest, the affected individuals will be informed by the following date: 31/08/2023

- Means by which notification will be made: Public statement or publication on corporate website

- ***CENTRO.2 is identified as the data controller and it is indicated that there is no data processor involved in the personal data breach

NINTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VIII of the LOPDGDD.

1. In relation to the results of the investigative actions concerning ***CENTRO.54 (hereinafter ***CENTRO.54):

On July 5, 2023, this agency notified this Agency of the personal data breach suffered by ***EMPRESA.1 and identified ***CENTRO.54 itself as the data controller and GETECCU as the processor.

On February 8, 2024, a document was received from ***CENTRO.54, in response to a request from this Agency, which attached, among others, the following relevant documents:

- Document 1.4: with a screenshot of an email sent from GETECCU (email address ***EMAIL.1) to ***CENTRO.54, on July 3, 2023, containing the following, among other content:

“- If data from (...) of ***CENTRO.54 has been affected, what volume are we talking about?

(...) approximately

(...)

Although the secondary storage system was encrypted, it could be decrypted due to the cybercriminal's access to a security programmatic token. Therefore, the data could have been decrypted.”

- Document 02: with the Record of Processing Activities of ***CENTRO.54, which lists the processing activity named “Research,” indicating that it processes the following personal data:

“• Identifying: Name, surname, NIF, Contact, home phone, Signature, Physical traits, TIS, SS

• Specially protected data: Health, Sexual life

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/77

• Personal characteristics: Date and place of birth, Marital Status, Age, Gender, Nationality, Family data (father, mother...), Physical or anthropometric characteristics.

• Social circumstances: Hobbies, lifestyle.

This document indicates as the legal basis for such processing "The consent of the data subject for the processing of their personal data."

-

Document 03: regarding the communication of the breach to the affected individuals, it was stated:

"The communication of the breach to the affected individuals was carried out by GETECCU from its website, as can be verified at the following link: ***URL.1."

A screenshot is provided with the content of this link, where the following communication can be seen:

"Dear patient:

From the Scientific Society "Spanish Working Group on Crohn's Disease and Ulcerative Colitis (GETECCU)", in our capacity as Data Controllers, we are contacting you to inform you of an incident that has affected information included in the National Study on Inflammatory Bowel Disease regarding Genetic and Environmental Determinants (Project "****PROJECT.1"), in which data of (...) with Inflammatory Bowel Disease is managed for statistical and scientific purposes. Your hospital participates in this project.

In this regard, (...), it was confirmed that it was a deliberate and malicious cyberattack. Immediately, the necessary measures were established to block this attack, and additional technical and organizational security measures were designed and implemented. At the same time, the security breach was communicated to the SPANISH AGENCY FOR DATA PROTECTION in strict compliance

with the regulations.

Among the information stolen, there are (...).

We would like to point out that in the project "****PROJECT.1", the highest levels of security, both technical and organizational, are used. Security processes are audited annually, and the technological infrastructure used is globally recognized for its high security standards and robustness. However, as is well known, unfortunately, no system is completely impenetrable.

We deeply regret any inconvenience or concern this situation may cause you. If you need any clarification, please do not hesitate to contact us via the following email legal@geteccu.org where we will be at your disposal to assist you.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/77

Sincerely,

Spanish Working Group on Crohn's Disease and Ulcerative Colitis (GETECCU)

Additional note on recommended security measures following the exposed incident:

We recommend that you consider the following security and preventive measures related to possible messages you may receive:

- 1) Unless your hospital usually uses email to contact you, be wary of any message related to your illness, and delete it, (...).
- 2) Similarly, if you receive any other type of message (telephone, SMS, postal mail, or by any other means) that you consider suspicious for not being a usual form of contact from your doctors or hospital, (...). In any case, it is important that you take these recommendations into account, as they are general security and protection measures that should always be taken, regardless of this incident."

-

Document 05: with the data processing contract signed between ***CENTER.54 and GETECCU, dated September 18, 2023. From its analysis, the following is extracted:

"***CENTER.54, as the data controller, authorizes GETECCU to process personal data on its behalf to the extent that this is necessary to provide the indicated service."

"The company GETECCU declares that it is capable of providing sufficient guarantees, applying appropriate technical and organizational measures, so that the processing of personal data is in accordance with the requirements of the GDPR and the LOPDyGDD, and commits to ensuring the protection of the rights of the data subjects."

"GETECCU has adopted the appropriate security measures to ensure the confidentiality, integrity, and availability of the information as well as the permanent resilience of the processing systems in the event of a physical or technical incident; implementing, in accordance with the First Additional Provision of the LOPDyGDD, the applicable security measures set forth in Royal Decree 311/2022 of May 3, which regulates the National Security Scheme in the field of Electronic Administration for an information system with the following security categorization: MEDIUM."

-

Document 06.2: screenshot evidencing an email received from GETECCU on June 26, 2023, with the notification of the incident, containing the following content:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/77

"Dear Researcher,

In relation to the study titled "National Study on Inflammatory Bowel Disease on Genetic and Environmental Determinants (***PROJECT.1)," we are contacting you to inform you, in a verifiable manner, that from ***COMPANY.1 (the technology company managing ***PROJECT.1), unauthorized

access has been detected to a secondary storage system that directly affects the personal data of (...) of ***PROJECT.1 that were included therein. Regarding the ***PROJECT.1 platform, we confirm that it has not been affected at any time by the attack and operates normally. The attacked element in question is a secondary storage system that does not interfere with daily operations and therefore does not affect the use of ***PROJECT.1.

Please forward this information to the Data Protection Officer (DPO) of your center (please verify first if your hospital is on the list of those we can confirm have been affected, which we are attaching to this email).

We will continue to inform you of any new details regarding this incident as quickly as possible.

Sincerely,"

-

Document 08.1: with the risk analysis of the affected activity, which includes:

- Analysis of the data lifecycle and description of the processing.
- Analysis of 39 risk factors and a list of selected measures to mitigate them, highlighting the following factors related to the breach:

□ (...)

- Documents 08.2, 08.3, and 08.4: with the list of security measures implemented by ***COMPANY.1, prior to the breach, those implemented to reduce the risk of receiving a similar attack, and new measures to prevent incidents, respectively. These documents will be analyzed later, in the documentation provided by GETECCU.

- Document 10: regarding the reason why the breach was not notified within 72 hours after detection, they stated:

"On June 26, 2023, GETECCU informed the Principal Investigator about the breach that occurred. It was interpreted that the breach had been communicated by the data processor; however, since it was communicated on June 30 to the Electronic Administration, Security, and Process Management Service of ***CENTER.54 (at that time the Security Section and User Service), as can be seen in document 6.2, and after investigations carried out together with the provider, it was deemed necessary to notify it also by ***CENTER.54, as it did."

2. In relation to the results of the investigation actions at ***CENTER.3 (hereinafter, ***CENTER.3):

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/77

On August 17, 2023, this agency notified this Agency of the personal data breach suffered by ***COMPANY.1 and identified ***CENTER.3 as the data controller and GETECCU as the processor.

On February 9, 2023, a document was received from ***CENTER.3, in response to a request from this Agency. From its analysis, the relevant information is extracted:

- They state that the number of people affected by this center is (...) (...).
- They provide a copy of the contract signed between ***CENTER.53 and GETECCU, dated March 15, 2018, which includes an annex with the list of security measures. The hiring of ***COMPANY.1 as the provider of the technological platform is authorized. The annex with the security measures is the same as that provided by GETECCU as a template model to be included in the contracts formalized with the centers; this document includes section "Table 2.11 with the list of relevant security measures to implement," which will be analyzed later.
- They provide a document with the communication of the breach to the affected parties by GETECCU. The content is the same as that provided by ***CENTER.54, transcribed above.
- They provide a document with the notification of the breach received from GETECCU, dated June 22, 2023 (and a subsequent update on July 3, 2023). From this last document, the following statements are extracted:

(...)

- They do not provide risk analysis or DPIA for the activities affected by the breach, both requested in

the requirement.

3. In relation to the results of the investigation actions at ***CENTER.4 (hereinafter ***CENTER.4): On August 9, 2023, this agency notified this Agency of the personal data breach suffered by ***COMPANY.1 and identified ***CENTER.4 as the data controller and GETECCU as the processor. On February 12, 2024, a document was received from ***CENTER.4, in response to a request from this Agency, containing, among other things, the following content:

- "After several conversations with the company and other participating hospitals in the project, the document is finally formalized on June 19, 2013, in which it is stated that GETECCU is responsible for the file and, at the same time, would sign a contract with ***COMPANY.1 as the data processor. Document signed on June 19, 2013 is attached as DOCUMENT NO. 1."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/77

- "Without prejudice to the actions taken by ***EMPRESA.1 and GETECCU and the communication to the AEPD within the deadline (data controller), the various Centers report the breach due to proactive responsibility, in accordance with what was stated by the Data Protection Officer of the Regional Health Management. Similarly, the breach was notified through a statement on our WEB portal (as was done by the other affected Hospitals in the SACYL network)."

- Attached as Document 1 is a copy of the contract dated June 19, 2013. From its content, the part corresponding to data responsibility is extracted:

- The contract is signed by ***CENTRO.55, identified as the "Initial Data Controller," and GETECCU, identified as the "Data Controller - Data Processor."

- Clause four: "In compliance with the provisions of the previous paragraph, the INITIAL DATA CONTROLLER authorizes by signing this contract the DATA CONTROLLER - DATA PROCESSOR: 1.- The subcontracting of the services for the PROCESSING OF THE ASSIGNED DATA to the entity ***EMPRESA.2. (...)"

- Annex A: includes an annex with a list of security measures, highlighting the following: "IDENTIFICATION/AUTHENTICATION:

(...).

ACCESS CONTROL:

(...)

- Attached as Document 5 is a public statement made by ***CENTRO.4 through the webpage, although it does not include a publication date, with the following content:

"STATEMENT ON A SECURITY BREACH IN THE NATIONAL STUDY ON INFLAMMATORY BOWEL DISEASE REGARDING GENETIC AND ENVIRONMENTAL DETERMINANTS ****PROJECT.1"

From the Management of ***CENTRO.55, in its capacity as the Data Processing Controller, an incident is communicated that has affected personal information included in the National Study on Inflammatory Bowel Disease regarding Genetic and Environmental Determinants (Project "****PROJECT.1", in which data of (...) with Inflammatory Bowel Disease is managed for statistical and scientific purposes.

***CENTRO.55 participates in this project.

In this regard, the Data Processing Officer of the Spanish Working Group on Crohn's Disease and Ulcerative Colitis (GETECCU) has detected a security incident, confirming that it was a deliberate and malicious cyberattack.

Immediately, the necessary measures were established to block this attack, and additional technical and organizational security measures were designed and implemented. At the same time, the data processor proceeded to communicate the security breach to the SPANISH AGENCY FOR DATA PROTECTION in strict compliance with the regulations. Subsequently, this Management also communicated this incident to the Spanish Agency for Data Protection.

Among the information stolen, there are identifying data and health data of (...) from this hospital center.

To date, we have no evidence of any actual harm to any of the affected individuals. Regarding the

clinical information, it is confirmed that it has not been altered or deleted, so specialists continue to have access to it with complete reliability.

We deeply regret any inconvenience or concern that this situation may cause to the (...) affected. If anyone needs clarification, please do not hesitate to contact us via the following email (gerente.cabu@saludcastillayleon.es), where we will be at your disposal to assist you.

Management of ***CENTRO.55.”

On February 12, 2024, a letter was received from ***CENTRO.4, in response to a request from this Agency, which included documentation provided by GETECCU.

In neither of these two letters was there evidence of a risk analysis or DPIA for the affected processing activity (requested in the requirement).

4. Regarding the results of the investigation actions on the SPANISH WORKING GROUP ON CROHN'S DISEASE AND ULCERATIVE COLITIS (hereinafter, GETECCU):

On February 21, 2024, a letter was received from GETECCU, in response to a request from this Agency, containing, among other things, the following content:

- Attached as document 01 is a document drafted by ***EMPRESA.1 with a description of the facts, the causes of the incident, and information about the measures implemented by this entity; from this document, the following relevant statements are extracted (the underlining is ours):

“On Wednesday, June 14, 2023, an incident was detected at ***EMPRESA.1 (...). (...) Immediately, measures were activated to block access and understand the details of the scope of the incident, and a security crisis response team was formed with internal personnel and external specialists. (...) From the same day of the attack, the implementation of new additional technical and organizational measures was carried out, on top of the existing layers of security and company policies, to provide the highest possible degree of security to both the affected system and the rest of the architecture and the company itself.”

“The security breach originated in (...).

“A preliminary list is shared with the main measures adopted by the technology provider immediately after the incident:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/77

(...)

In addition to the measures adopted immediately after the incident, an additional set of technical and organizational measures was established to be implemented as quickly as possible. These measures were implemented over the following weeks:

(...)

- Document 02 is attached, which is the template included when formalizing a new contract between GETECCU and a Hospital Center wishing to join the ***PROJECT.1. This document includes the following clarification: “THIS ANNEX MUST BE INCLUDED IN THE AGREEMENT BETWEEN GETECCU AND EACH NEW PARTICIPATING ORGANIZATION IN THE PROJECT.” Furthermore, this template includes the following relevant paragraphs:

(...)

- Document 03 is attached, which is a screenshot of an email from the address ***EMAIL.2, directed to the addresses ***EMAIL.3, ***EMAIL.4, ***EMAIL.1, on June 16, 2023, at 3:49 PM, with the following content:

“Dear A.A.A., B.B.B., and C.C.C., as D.D.D. has already informed you, we are sending you the following communication regarding the attack we have suffered. We will keep you promptly informed about the progress of the analysis we are conducting. Both D.D.D. and I are at your complete disposal for any related questions. Best regards.

Dear Client,

We are contacting you to inform you, in a reliable manner, that ***COMPANY.1 has detected unauthorized access to a secondary storage system that directly affects the personal data stored in a

database for which you are Responsible or Processor. Specifically, and although we are currently immersed in an investigation process, diligently working to determine the magnitude and scope of the attack, we hereby provide you with the information we have as of the current date:

(i) Date the security breach was detected: In the afternoon of Wednesday, June 14, 2023.

(ii) Nature of the breach: Unauthorized access to files in the secondary storage system with deletion and possible download of the same.

(iii) Affected projects: ***PROJECT.1.

(iv) Potential number of affected data: 83,067

(v) Categories of affected data: - Identifying data - Contact data - Health data

(vii) Measures adopted to remedy the security breach and mitigate risks by ***COMPANY.1: Our priority is to protect the privacy of those affected, which is why since (...)

We also take this opportunity to communicate, in our capacity as Processors of the data, and in accordance with Article 33.2 of the GDPR, our willingness to collaborate at all times so that you can carry out the corresponding communication to the Spanish Data Protection Agency."

- Document 04.1 is attached, which is a screenshot of an email sent from GETECCU (***EMAIL.1) on June 26, 2023, to the recipients ***EMAIL.5, ***EMAIL.6, ***EMAIL.7, ***EMAIL.8, ***EMAIL.9, ***EMAIL.10 with the following content:

"Dear researcher, Regarding the study titled "(***PROJECT.1)" we are contacting you to inform you, in a reliable manner, that ***COMPANY.1 (the technology company managing ***PROJECT.1) has detected unauthorized access to a secondary storage system that directly affects the personal data of (...) from ***PROJECT.1 that were included therein. Regarding the ***PROJECT.1 platform, we confirm that it has not been affected at any time by the attack and operates normally. The attacked element in question is a secondary storage system that does not interfere with daily operations and therefore does not affect the use of ***PROJECT.1.

Please forward this information to your DPO (please verify first if your hospital is on the list of those we can confirm have been affected and which we accompany in this email)."

- Document 04.2 and 04.3 are attached, which are screenshots of two other emails, with identical content to the previous one and sent on June 26, 2023, from GETECCU (***EMAIL.1) to more than 40 different email addresses, which may correspond to the hospital centers affected by the breach; however, they are not visible in the provided screenshot, and a new request for information is made to clarify this aspect.

- Document 05 is attached, in response to the request from this Agency for clarifying information about the roles in data protection assumed by each entity in the ***PROJECT.1 project, a document from GETECCU in which they state:

"To participate in the ***PROJECT.1 project, interested centers obtain approval from their local Ethics Committee and sign a contract with GETECCU and the researcher, a medical specialist from the center."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/77

hospital and associated with GETECCU. After that, the center accesses the website where the database is located."

"GETECCU receives anonymized information (no personal data), so it does not process personal data that identifies, or makes identifiable, individuals. (...) Therefore, since there is no processing of personal data by processing anonymized information, which falls outside the scope of the GDPR, it cannot be understood that there is a data controller or a data processor.

Notwithstanding the above, subsidiarily, in the event that it is understood that there is indeed processing of personal data, and therefore, the figures of the data controller and, where applicable, the data processor must be applicable, each of the healthcare centers would be the data controller of the personal data, while the role of data processor would fall on GETECCU and that of sub-processor on ***EMPRESA.1. It is these healthcare centers that collect the information for their own purposes

through the physician attending to the patient, with the aim of providing them with healthcare assistance and, additionally, secondly, to carry out studies that promote the development of medicine and a better understanding of diseases and treatments, so that this results in better and more efficient healthcare assistance to them.

...the research is conducted in the healthcare centers themselves, with their own physicians participating as principal investigators, directly conveying to organizations such as GETECCU the instructions regarding the data to be processed, for what purposes, for how long such data should be retained, and what technical and organizational security measures should be applied, all of which is reflected and recorded in the corresponding data processor contracts in which GETECCU acts as a data processor on behalf of and under the instructions of the healthcare centers, and as sub-processor, its technical provider ***EMPRESA.1.

We substantiate the statements made with the provision, by way of example, of the data processor contract signed with the Health Service of Navarra. And the contract signed between this same service and ***EMPRESA.1.”

-

Document 05.1 includes a copy of the contract formalized between GETECCU and ***CENTRO.54, dated September 18, 2023. From its analysis, the following relevant texts are extracted:

“Through these clauses, the conditions are established that enable GETECCU to process, on behalf of ***CENTRO.54 (hereinafter ***CENTRO.54), the DATA CONTROLLER, the personal data derived from the provision of the contracted service.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

22/77

SPANISH WORKING GROUP ON CROHN'S DISEASE, hereinafter GETECCU, will process, to the extent that execution makes it indispensable, personal data for which ***CENTRO.54 is responsible.”

“The processing will consist of the provision of the following service: Carrying out the project ***PROYECTO.1, which aims to promote clinical/genetic studies based on a significant volume of (...), as well as to offer a common working tool to the members of GETECCU. To this end, it is necessary to develop a database with the aim of obtaining the selected variables on various aspects of the disease (epidemiological, clinical, drug safety, etc.) for subsequent scientific exploitation, which will last for the duration of the project.

***CENTRO.54, as the data controller, authorizes GETECCU to process personal data on its behalf to the extent that this is necessary to provide the indicated service.”

In its Annex I, it states: “Data subject to processing:

- Identifying data of the patient: - Name - Surname - Gender - Date of birth - Phone number - Address.
- Identifying data of the designated physician: - Name - Surname
- Health data: - Symptoms - Diagnosis - Physical condition - Medication.”

-

Document 06 includes the risk analysis for the affected processing activity, among them the activity “Development of Scientific Research Projects in Collaboration with Hospital and Health Centers.”

From the analysis, the following relevant statement is extracted:

In its section on “Security of processing,” the element “There is unauthorized access to personal data” is assigned a probability degree of “Unlikely,” an impact of “Very significant,” and a risk of “Very high.”

And the document concludes:

“After evaluating the risk considering the probability of materialization of the detected threats and the impact that such materialization would have, it has been estimated that the average risk level of the processing, taking into account the personal data processed, the context, and the environment is MEDIUM, for which legal, technical, and organizational measures have been applied, so that the risk level, while not high, has been mitigated.

In addition to the above, it is not considered necessary to carry out an impact assessment as the

detected average risk is at a MEDIUM level, so the implemented measures are sufficient to mitigate it.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/77

This allows GETECCU to carry out its activities with guarantees, without prejudice to the periodic review of such legal, technical, and organizational measures in order to keep them updated.

GETECCU has all its treatments outsourced as its activity is based, precisely, on collaboration with third parties, so it verifies and checks the measures that third-party providers apply to personal data.

-

Document 7 is attached, which outlines the procedure implemented at GETECCU for managing security breaches, although it does not contain any signatures or dates of creation or update. Its content includes information about the channels for reporting incidents and the notification obligations to both the AEPD and affected individuals. However, it does not include information about tasks, roles, and responsible persons for carrying them out. A document from ***EMPRESA.1 titled "Notification and Communication of Incidents" (original in English) is also attached.

-

Document 08 is attached, which relates to the types of data affected by the breach, in which they state: "The types of data affected by the attack were:

(...)

-

Document 09 is attached, explaining how personal data was entered into the platform by the hospital centers:

"The data is incorporated into the main platform through forms designed for data entry in the project. Users (gastroenterologist doctors from the participating hospitals in the project) access these forms through a Login page."

A screenshot of the platform's home screen (initial Login) and a screenshot of the main software interface once logged in are provided; this shows the different tabs that provide access to the forms for collecting data. Details of the form for patient identification data are not visible.

-

Document 10 is attached, containing statements provided by ***EMPRESA.1 clarifying several points of the expert report. It is highlighted (the underlining is ours):

-

Regarding the reason for using programmatic tokens, it is stated:

(...)

-

Regarding the improvements introduced after the breach for log monitoring, it is stated:

(...)

-

Regarding the improvements introduced for the management of programmatic tokens, it is stated:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/77

(...)

-

Regarding the improvements to the data encryption system, it is stated:

(...)

-

Document 12 is attached, explaining the possible use by third parties of the data leaked in the breach:

"As of February 6, 2024, ***EMPRESA.1 has had no knowledge of the use of the affected personal data from the cyberattack on June 14, 2023, by any third party."

-

A document from ***EMPRESA.1 titled "NEW TECHNICAL AND ORGANIZATIONAL MEASURES ADOPTED BY ***EMPRESA.1 TO AVOID, AS MUCH AS POSSIBLE, SECURITY INCIDENTS LIKE THE ONE THAT OCCURRED" is attached, containing the action plan with the list of reactive measures implemented to prevent similar incidents. From its analysis, the following statements are extracted (the underlining is ours):

(...)

On April 18, 2024, a second letter was received from GETECCU, in response to a request from this Agency, containing, among other things, the following content:

-

Regarding the possible delay in notifying the hospital centers, it is stated:

"First of all, it is important to emphasize that GETECCU is a scientific association, so the speed of decision-making processes and their execution should not be compared with that of other types of entities more accustomed to commercial traffic. The Board of Directors of the Association is made up of doctors residing in different locations in Spain, who are part of the Association in order to research inflammatory bowel diseases.

Secondly, we highlight the complexity of the project due to the number of centers and (...) of it; it was necessary to review and ensure the scope of the incident.

GETECCU had to investigate who had access to this data within the security incident and what precautionary measures should be taken when determining whom to notify about the incident. At the same time, it had to conduct an assessment of how the security breach could affect, and consequently, who could have access to the compromised information. Finally, although it is true that on June 16, 2023, Friday, was when the president of the Association became aware of the facts, first by phone and subsequently by email sent by the technology provider, it is equally true that at that moment the centers were unknown.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/77

affected and the extent of the damage, so nothing could be done. It was on Monday, June 19, when the names of the affected centers began to be known, which was not definitive.

By Thursday, the notification was sent to the hospital centers, but something went wrong and the emails were not sent correctly, reaching only 6 centers. The Board of Directors of the Association was informed of this issue and proceeded to resend the email on June 26, 2023. We confirm the sending of the email dated June 22, 2023 (Document 7).

-

Regarding GETECCU's access to the affected personal data, it is stated: "GETECCU has been assigned a role that allows it to export information anonymously from the platform. The processes of anonymization of the data are carried out in the technological architecture, so at no time does GETECCU have access to sensitive data. The affected personal data corresponds to the exports made by the centers, as the role they have associated does allow them to see and access the personal information of their center."

-

Screenshots of the emails sent by GETECCU to the affected centers notifying them of the breach on June 26, 2023, are attached as Documents 1-4, in which the email addresses to which they were sent can be seen, affected hospital centers by the breach.

-

The following list of hospitals affected by the breach is attached as Document 5:

(...)

-

In the response letter to this Agency, it is stated: "Between ***COMPANY.1 and GETECCU there is a data processing contract titled 'EXHIBIT C: USE OF TECHNOLOGY AND DATA PROCESSING', linked to the project ***PROJECT.1, which is attached (Document No. 8)." From the analysis of this document, the following information is provided:

-

The document is signed by both parties on February 13, 2019.

-

The following text stands out regarding the roles assumed by each of the parties in the project (the term USER refers to the center that uses the platform and PROVIDER refers to ***COMPANY.1): "Within the scope of this agreement, USER is solely responsible for the processing, and PROVIDER acts as the data processor. GETECCU is the facilitator of THE_PROJECT and acts as the data processor of the data. Likewise, GETECCU is solely responsible for the processing of the database ***PROJECT.1. PROVIDER will be the data processor of the personal data, owned by USER as the data controller, in accordance with the provisions of the current regulations in this matter in our legal system."

-

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

26/77

-

The contract includes a descriptive table with the controls and security measures to be implemented by the data processor (the underlining is ours):

(...)

-

Regarding the contracts formalized with each of the affected hospital centers, it is stated:

"A copy of all the data processing contracts of Project ***PROJECT.1 signed with the different hospital centers for which services are being provided is provided, which include their authorization to contract with sub-processors. As indicated in the shared documentation, GETECCU offers a common working tool to its members (the registry ***PROJECT.1), in order to promote clinical studies in the field of Inflammatory Bowel Disease. For the technical implementation and maintenance of the project, GETECCU contracted the provider ***COMPANY.2, predecessor of ***COMPANY.1, which took over its position, providing said technological service since then."

"Currently, GETECCU is carrying out a continuous phase of adaptation of the agreements, which requires a bit more time than that of an ordinary commercial entity, as the decision-making and execution processes in a Scientific Society require the assessment of different governance bodies that change periodically. Nevertheless, GETECCU has designated a specialized company that is providing the necessary support, with the aim of accelerating the adaptation procedure of the agreements as much as possible."

Copies of the following documents and formalized processing contracts are provided (all included in annexes "document No. 9.pdf" and "document No. 10.pdf" of the letter):

-

Copy of the processing contract signed between ***CENTER.5 (as data controller) and ***COMPANY.2 (as data processor), dated October 3, 2012. Includes an annex with technical and organizational security measures.

-

Copy of the processing contract signed between ***CENTER.6 (as data controller) and ***COMPANY.2 (as data processor), dated July 28, 2011. The content is the same as the previous contract.

-

Copy of the processing contract signed between ***CENTER.7 (defined as the Initial Data Controller) and GETECCU (defined as the Data Controller-Data Processor), dated November 10, 2014, includes obligations of the parties and authorization to contract ***COMPANY.2 as a sub-processor. Includes an annex with security measures. The following paragraph stands out: "HOSPITAL and GETECCU maintain a professional collaboration relationship for the purpose of using the software ***PROJECT.1. That for the execution of said services is...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/77

necessary for GETECCU to access and manage data files owned by HOSPITAL that contain personal data"

- Copy of the service contract signed between ***CENTRO.8 and GETECCU, dated March 8, 2017. Subcontracting of ***EMPRESA.1 is authorized. Includes Annex with security measures and data processing, from which the following paragraph is extracted: "Within the scope of this agreement, HOSPITAL will remain the responsible owner of the hospital management and medical care files. GETECCU is the owner of the file ***PROYECTO.1, as well as the data processor of the same and facilitator of the project ***PROYECTO.1."

- Copy of the contract signed between ***CENTRO.9, a medical researcher from ***CENTRO.10, and GETECCU (defined as Promoter), signed on November 18, 2014. Subcontracting of ***EMPRESA.2 is authorized, which assumes the role of data processor. The following paragraph stands out: "The subcontractors, who also have the status of data processors, will also be obliged to comply with the obligations established for the promoter. The promoter will be liable to the CENTRO for any non-compliance by the subcontracted entities."

- Copy of the service contract between ***CENTRO.11 (as data controller) and ***EMPRESA.2 (as data processor), dated February 22, 2012. Includes the obligations of the parties and an annex with security measures.

- Copy of the service contract between ***CENTRO.12 and GETECCU, dated January 16, 2017, with the following relevant texts:

"GETECCU, owner of the file ***PROYECTO.1, not having the necessary technical means, has contracted the services of a technology provider that ensures the preservation and integrity and will adopt all security measures to prevent any misuse or fraudulent use of computer files used or developed. All terms related to the use of technology and data processing are included in Annex A."

"Within the framework of this agreement, HOSPITAL will remain the responsible owner of the hospital management and medical care files. GETECCU is the owner of the file ***PROYECTO.1, as well as the data processor and facilitator of the project ***PROYECTO.1."

"GETECCU has contracted the platform from ***EMPRESA.1 which will make every effort to ensure the preservation and integrity of the documents and/or information and will adopt all measures to prevent any misuse or fraudulent use of computer files used within the framework of the agreement."

- Copy of the service contract between ***CENTRO.13 and ***EMPRESA.2, dated March 29, 2012.

- Copy of the service contract between ***CENTRO.14 (as the initial data controller) and GETECCU (data controller - C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es

28/77

data processor), dated March 26, 2015. Its content authorizes the subcontracting of ***EMPRESA.2.

-

Copy of the contract between ***CENTRO.15 (as data controller) and GETECCU (as data processor), dated April 26, 2013. The subcontracting of ***EMPRESA.2 is authorized, which assumes the role of data processor of the data. Includes an annex with security measures.

-

Copy of the contract between ***CENTRO.16 (as data controller) and GETECCU (as data processor), dated May 6, 2013. The subcontracting of ***EMPRESA.2 is authorized, which assumes the role of data processor. Includes an annex with security measures.

-
Copy of the contract signed between ***CENTRO.17 (as data controller) and ***EMPRESA.2 (as data processor), dated January 13, 2012.

-
Copy of the contract between ***CENTRO.18 and GETECCU, dated April 28, 2017. Subcontracting is authorized for the use of the ***EMPRESA.1 platform.

-
Copy of the contract between ***CENTRO.19 and GETECCU, dated October 22, 2014. The subcontracting of ***EMPRESA.2 is authorized.

-
Copy of the contract between ***CENTRO.20 and GETECCU, dated February 25, 2014. The subcontracting of ***EMPRESA.2 is authorized. It includes an annex with security measures.

-
Copy of the contract between ***CENTRO.21 and GETECCU, dated January 2019. The subcontracting of ***EMPRESA.1 is authorized. The following texts are highlighted:
"The Hospital consents that the researcher, once informed consent from the patient has been obtained, accesses the data of their medical history that are strictly necessary for the development of the project ***PROYECTO.1, with the hospital maintaining ownership of the hospital management and medical care files."
"GETECCU, owner of the file ***PROYECTO.1, not having the necessary means for hosting and IT support, has contracted the services of a technological provider that ensures the preservation and integrity of the documents or information and will adopt all security measures to prevent any fraudulent misuse of the IT files used or developed."

-
Copy of the contract between ***CENTRO.22, the PRINCIPAL INVESTIGATOR, and GETECCU (PROMOTER), signed on September 24, 2013. This is not a contract for the processing of personal data, although it includes a NINTH clause on the protection of personal data, including the following text: "The FOUNDATION will have the necessary actions so that the INVESTIGATOR processes the documentation, information, results, and data related to the study in accordance with its confidential and secret nature, ensuring the restricted circulation of such information and C/ Jorge Juan, 6
www.aepd.es 28001 – Madrid sedeagpd.gob.es

29/77
ensuring that this obligation is fulfilled by all individuals who must have access to it. In relation to the obligations of the promoter of the trial, when personal data of researchers and (...) are stored and processed, appropriate measures must be taken to protect them and prevent access to them by unauthorized third parties in accordance with Law 15/99. The FOUNDATION acknowledges the PROMOTER's ownership of the data and results derived from the study subject to this contract.

-
Copy of the contract of assignment between ***CENTRO.23 (as data controller) and ***EMPRESA.2 (as data processor), dated February 24, 2012. Includes an annex with security measures.

-
Copy of a contract formalized between ***CENTRO.24 and GETECCU, dated June 6, 2019, with the following content in its EIGHTH clause: Protection of Personal Data:
"The Researcher will treat the data of the participants as indicated in the Protocol. Only the individuals indicated in the information sheet and in the informed consent may access the personal data of the subjects."
"The Promoter will ensure that the personal data contained in the documentation related to the study has been collected in accordance with applicable regulations, providing the necessary information, expressly informing about the destination of the data, and obtaining consent from the data subjects."
"The data controller of the personal data (by the Center) is (...), (by the managing entity) (...), (by the Promoter) GETECCU."

-
Copy of the contract between ***CENTRO.24 (as data controller) and GETECCU (as data processor),

dated November 12, 2013. Includes authorization to subcontract to ***EMPRESA.2. Includes an annex with security measures.

-

Copy of the contract between ***CENTRO.25 (as data controller) and GETECCU (as data processor), dated June 10, 2013. Includes authorization to subcontract to ***EMPRESA.2. Includes an annex with security measures.

-

Copy of the contract between ***CENTRO.26 and GETECCU, dated November 22, 2015, which is a general contract for conducting the study in EII, highlighting point 9. Protection of Personal Data which includes:

"The file or files of personal data will be provided by the HOSPITAL to GETECCU, at all times the center retains the exclusive right of ownership and use of the same, as well as all its updating processes. GETECCU will process the personal data provided by the HOSPITAL in accordance with the instructions given by it, and for purposes and uses exclusively necessary for the development."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/77

of the provision of services detailed in this contract, not being able to use it for a different purpose."

"It is authorized to subcontract to the entity ***EMPRESA.2, which assumes the role of data processor."

Includes annex with security measures.

-

Copy of the service agreement between ***CENTRO.27 (as data controller) and ***EMPRESA.2 (as data processor), signed on September 5, 2012.

-

Copy of the service agreement between ***CENTRO.28 (as data controller) and ***EMPRESA.2 (as data processor), signed on February 7, 2012. Incorporates annex with security measures.

-

Copy of the service agreement between ***CENTRO.2 (as data controller) and ***EMPRESA.2 (as data processor), signed on August 9, 2012. Includes annex with security measures.

-

Copy of the service agreement between ***CENTRO.53 and GETECCU, signed on March 15, 2018. Refers to Directive 95/46/EC. Includes authorization to subcontract to ***EMPRESA.1.

-

Copy of the service agreement between ***CENTRO.29 (as data controller) and GETECCU (as data processor), signed on May 13, 2013. Subcontracting to ***EMPRESA.2 is authorized. Includes annex with security measures.

-

Copy of the service agreement between ***CENTRO.30 (as data controller) and ***EMPRESA.2 (as data processor), signed on June 1, 2012. Includes annex with security measures.

-

Copy of the contract between ***CENTRO.31 and GETECCU, signed on February 8, 2021. Authorizes the hiring of the services of a technology provider for hosting and IT support and mentions (but does not include) an Annex A with terms related to technology and data processing (second clause of the contract).

-

Copy of the service agreement between ***CENTRO.32 (as data controller) and ***EMPRESA.2 (as data processor), signed on March 28, 2012. Includes annex with security measures.

-

Copy of the service agreement between ***CENTRO.33 (as data controller) and ***EMPRESA.2 (as data processor), signed on May 10, 2012. Includes annex with security measures.

-
Copy of the service agreement between ***CENTRO.34 (as data controller) and GETECCU (as data processor), signed on January 9, 2014. Includes authorization to subcontract to ***EMPRESA.1, as well as an annex with security measures.

-
Copy of the service agreement between ***CENTRO.35 (as data controller) and ***EMPRESA.2 (as data processor), signed on October 30, 2012. Includes annex with security measures.

-
Copy of the service agreement between ***CENTRO.36 (as data controller) and ***EMPRESA.2 (as data processor), signed on February 29, 2012. Includes annex with security measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/77

- Copy of the contract of engagement between ***CENTRO.37 (as data controller) and ***EMPRESA.2 (as data processor), dated May 9, 2012. Includes an annex with security measures.

- Copy of the contract of engagement formalized between ***CENTRO.38 (as data controller) and GETECCU (as data processor), dated October 21, 2014. Includes authorization for subcontracting to ***EMPRESA.2. The following text is highlighted: “The researchers will adequately dissociate the personal data of the subjects included in the study so that they cannot be identified.”

- Copy of the contract of engagement between ***CENTRO.39 (as data controller) and ***EMPRESA.2 (as data processor), dated May 10, 2012. Includes an annex with security measures.

- Copy of the contract of engagement between ***CENTRO.40 (as data controller) and ***EMPRESA.2 (as data processor), dated May 10, 2012. Includes an annex with security measures.

- Copy of the contract of engagement between ***CENTRO.41 (as data controller) and ***EMPRESA.2 (as data processor), dated April 10, 2012. Includes an annex with security measures.

- Copy of the contract signed by ***CENTRO.42 (as data controller), ***CENTRO.43, the Principal Investigator, and GETECCU (as data processor), dated December 12, 2017. Incorporates an annex with security measures. Includes the following text: “GETECCU has contracted the services of a technology provider that ensures the preservation and integrity of the documents and information, and will adopt all measures, including hardware security measures, to prevent any misuse or fraudulent use of computer files used or developed. All terms regarding the use of technology and data processing are included in Annex A attached.”

- Copy of the contract of engagement between ***CENTRO.44 (as data controller) and GETECCU (as data processor), dated December 21, 2013. Includes an annex with security measures and authorization to subcontract to ***EMPRESA.2.

- Copy of the contract of engagement between ***CENTRO.45 (as data controller) and ***EMPRESA.2 (as data processor), dated February 9, 2012. Includes an annex with security measures.

- Copy of the biomedical research contract between ***CENTRO.46 and GETECCU, dated January and February 2023 (according to the signing party). Incorporates “Clause 8: Obligations of the parties, confidentiality, and data protection” with the following relevant text: “Once the information is transferred to the COORDINATOR (GETECCU), the CENTER and the INVESTIGATOR are not responsible for the use that the COORDINATOR makes of the provided data, transferring all obligations and responsibilities described in this agreement.” “The researcher from the CENTER commits to providing the COORDINATOR of the STUDY (GETECCU) with duly dissociated information (pseudonymized or anonymized), that is, without including any information that allows the direct identification of the participants in the STUDY, protecting their identity and complying with the current legal requirements for such transfer.”

- Copy of the contract of engagement between ***CENTRO.47 (as data controller) and GETECCU (as data processor), dated June 19, 2013. Includes authorization to subcontract to ***EMPRESA.2. Includes an annex with security measures.

- A document signed by the Managing Director of ***CENTRO.48, dated February 21, 2023, with the

following text: "That he is aware of the proposal made by GETECCU, as promoter, for the National Study on Inflammatory Bowel Disease to be conducted at this center, which will be carried out in the Digestive System service by the Principal Investigator, who commits to carrying it out in accordance with the protocol authorized by the CEIM and the applicable provisions. That he accepts the execution of said Research Project at this Center."

- Copy of the contract of engagement between ***CENTRO.49 (as data controller) and GETECCU (as data processor), dated September 24, 2021. Includes authorization to subcontract to ***EMPRESA.1. Includes an annex with security measures.

- Copy of the contract of engagement between HOSPITAL UNIVERSITARIO DE BURGOS (as data controller) and GETECCU (as data processor), dated June 19, 2013. Includes an annex with security measures. Includes authorization to subcontract to ***EMPRESA.2.

Taking into account the information obtained, the following table is prepared summarizing the impact of the breach:

(...)

5. In relation to the results of the research actions at ***CENTRO.50:

On September 2, 2024, a written response was received from ***CENTRO.50, in response to a request from this Agency, containing, among other things, the following content:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/77

-

In relation to the responsibility for the processing of the affected data, it is stated (the underlining is ours):

[the database of ***PROJECT.1] "... originates from a record whose owner and responsible party is GETECCU and not ***CENTER.50 (hereinafter, ***CENTER.50)."

"The researchers participating in Project ***PROJECT.1 may be authorized by the centers to access the clinical history (HC) data of the (...) that meet the requirements of ***PROJECT.1 and enter them into the database owned by GETECCU."

"From GETECCU's perspective, as defined in Article 2 of its statutes: the primary object or purpose of the Association is to stimulate the study and research of Inflammatory Bowel Disease and to seek the standardization of clinical-therapeutic criteria in its diagnosis and treatment, for which it proposes:

1. To promote the development of suitable therapeutic means through research at all levels, basic, experimental, clinical, and epidemiological.

2. To seek the coordination of these means in a harmonious and complementary manner.

3. To stimulate the uniformity of criteria for the treatment of inflammatory bowel disease."

Therefore, considering the definition of promoter included in Article 2 of Royal Decree 1090/2015, of December 4, which regulates clinical trials with medicines, as: 'Individual, company, institution, or organization responsible for initiating, managing, and organizing the financing of a clinical trial', it can be considered that GETECCU holds the status of research promoter for this Project."

"In accordance, since GETECCU acts as a promoter, following the criteria established by the AEPD itself in both the legal report N/REF: 0004/2022 and in report N/REF: 0038/2021, the following conclusion is reached:

The promoter is responsible for the processing of data for clinical purposes with medicines, having to make decisions regarding the purposes and means in accordance with the provisions of Regulation (EU) 536/2014 and Royal Decree 1090/2015 that have been presented."

Provisions that are specifically applicable in relation to the references for this type of research included in Article 16.3 of the LAP when it contemplates the uses of the clinical history for research purposes."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

"The healthcare center is responsible for the processing of data from the clinical history under the terms established in the LAP and the autonomous regulations governing this matter for the purposes provided for in said regulations; except in relation to the uses of the same for health research purposes in the modality of clinical trials which, as noted, are governed by the terms provided in the Royal Decree on clinical trials with medicines. According to the provisions of this regulation, its intervention as the data processor is limited to authorizing access to the clinical history of the trial subject by personnel contracted by third parties, such as the monitor or the CRO. Access may be structured through a document distinct from a contract and the figure of the data processor, in which specific guarantees for the performance of their functions are established.

Thus, from the reiterated doctrine of this AEPD, it follows that the Hospital (independently of the Promoter) only acts as the data processor of the clinical history data that may be used in the research. In this case, the Center, as the responsible party for the aforementioned clinical history data, has carried out the necessary analyses and established the corresponding security measures for the proper processing of said information.

In this same sense, the aforementioned Code of Conduct determines that:

'Thus, to the extent that the Promoter determines the criteria for the participants whose coded data must be included in the CRD of the clinical research, it will be considered responsible for the processing of said data, with the Center (and/or, where applicable, the Principal Investigator) being responsible for the processing of the data of the participants in the clinical research for the purpose of providing adequate healthcare to them within the framework and development of the research.'

"... it is evident that in this case GETECCU determines the purposes and means of processing the personal data of the participants in the development of Project ***PROJECT.1, being responsible for the processing of the personal data included in said database."

"In relation to the role played by ***CENTER.50 in said Project, and considering that GETECCU is the data processor of ***PROJECT.1, it is important to note that the Center has only limited itself to authorizing, regarding the requesting researcher, access to the clinical histories of their (...), not intervening in any subsequent phase of the study. This has been done so that the researcher can transfer the relevant information to the database of ***PROJECT.1, a Project in which the professional participates independently of the Hospital. Without GETECCU acting in any case as the data processor of the Center, since it does not carry out any activity on behalf of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Hospital regarding the personal data collected in the database

***PROJECT.1, subject of the breach that gives rise to this request."

"In relation to the transfer of special category data (HC) that is made to the researchers who request it, it should be understood that such transfer is legitimized in accordance with the provisions of Article 6.1 c) of the GDPR, in connection with the provisions of Article 9.2 i) 'the processing is necessary for reasons of public interest in the field of public health'... and Article 9.2.j) 'the processing is necessary for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes, in accordance with Article 89, paragraph 1, based on Union or Member State law, which must be proportional to the objective pursued, respect the essence of the right to data protection, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject.'"

"...the Hospital acts in accordance with current regulations, authorizing access to the medical records of its (...) exclusively so that the researcher can fulfill the scientific and research purposes of the Project ***PROJECT.1."

"...in support of this argument, we must point out that, although the Center has given its consent for

the study to be conducted on its premises and has authorized access to the data of the (...) involved, the researchers who wish to access and include that information in the database of ***PROJECT.1 must obtain prior informed consent from said (...) for the processing of their data and its possible communication to third parties.”

-

In relation to the notification of the breach to this Agency and the number of affected individuals, it is stated (the underlining is ours):

“GETECCU, after detecting the breach, proceeds to contact all the researchers who were part of the Project to inform them about the incident. It is through this channel -by the researcher- where the Hospital becomes aware of the events that occurred and contacts the Delegated Committee for Data Protection of the Health Department of the Community of Madrid to carry out the actions that may be necessary, even though it is not responsible for the processing of said database. The Center assessed the level of risk of this incident on the rights of the affected citizens, using the internal tool of the Health Department for managing security breaches, in which it was recorded that the number of (...) affected amounted to a total of (...) and it was confirmed that there was no need to communicate to the supervisory authority. Furthermore, based on the level of risk of the incident, taking into account the volume and type of affected data and the nonexistent impact caused to the data subjects, it was estimated that it was not necessary to inform the affected individuals.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
36/77

- Attached as Annex III is the authorization model issued by the hospital to the investigator for access to the medical records of the (...) (that meet the sample criteria of the project). From this document, the following statements are extracted (the underlining is ours):

“Authorize the applicants access to the medical records of the (...) that meet the sample criteria of the project....

However, given that access is directly to the (...) and clinical records, records, and consequent data that are not dissociated, it will be mandatory that, prior to this, the (...) that meet the sample criteria issue the appropriate consent for the processing of non-dissociated data and its communication to third parties, which must be documented and whose custody is the responsibility of the research team until the completion of the work.”

- Attached as Annex VI is the document with the consent model that is provided to the (...), from which the following relevant paragraphs are extracted (the underlining is ours):

“In the event that you grant us authorization, we will access the data from your medical record that is strictly necessary and, together with other data that you specifically provide us for this project, will be transferred to a database constructed for this purpose. The owner and responsible party for this database is the Spanish Working Group on Crohn's Disease and Ulcerative Colitis (GETECCU), a non-profit association with CIF G07762669. The location of the server where the clinical information is stored will be the headquarters of ***EMPRESA.1....”

“Access to the clinical data of the (...) participants, appropriately coded, will be granted to researchers who present a research project that has been approved by an ethics committee, once it is also approved by the scientific committee of the project ***PROYECTO.1, composed of a minimum of seven doctors from seven Spanish hospital centers.”

“The use of your data by any doctor or health professional for the purpose of conducting clinical or epidemiological studies will be done in a coded manner, under a code that will not allow for the recognition of your identity in any case.”

- Attached as Annex I is a document sent from the Legal Office of the Hospital to a researcher from the same center in August 2012, from which the following text stands out (the underlining is ours):

“The project ***PROYECTO.1 is a study that aims to identify genetic and environmental determinants that affect inflammatory bowel disease (...) The study is based on the identification of each subject sample through clinical (healthcare) contact and will rely on two tools: Biobank and Database, the

latter being a fundamental tool where all personal and health data of (...) sample and the people in their environment, when applicable, will be recorded. The database will be constructed without dissociation. There will also be no dissociation in the use of the medical history of the sample subjects who consent to participate in the project. (...) The person responsible for the project database is not the Management of each participating center. (...) The Management must limit its scope of action to issuing authorization for participation to the professionals of the Public Entity and the Public Entity itself in the project ***PROYECTO.1. Such authorization, combined with the consents that each patient individually provides (...), is sufficient.”

6. In relation to the results of the research actions at ***CENTRO.51:

On September 3, 2024, a letter was received from ***CENTRO.51, in response to a request from this Agency, containing, among other things, the following content:

- “According to GETECCU, the number of (...) affected belonging to ***CENTRO.51 has been (...), unknown to us.”
- “The subcontracted company for the processing, ***EMPRESA.1, did not directly inform ***CENTRO.51 of the breach, but only the data processor, GETECCU, which reported the breach to the AEPD on July 11, 2023. On July 26, 2023, GETECCU informed the researcher at ***CENTRO.51 via email about the existence of the personal data security breach, expressly indicating that ‘you do not need to make any notification in this regard.’ This information was taken literally by the professional and, as a consequence, the center's managers were not informed. This was the reason why the breach was not reported to the AEPD...”

Attached as Annex I is the email sent on July 26, 2023, from GETECCU containing, among other things, the following content (the underlining is ours): “From GETECCU, in the capacity of Data Controller, we are contacting you to inform you of an incident that has affected the information included in Project ***PROYECTO.1 (...) Among the information stolen are identifying data and health data of (...) from the mentioned project. (...) The PIs of ***PROYECTO.1 from all centers have been informed, and the relevant procedures have been carried out by GETECCU and each affected center. Therefore, it is not necessary for you to make any notification in this regard...”

- “Having become aware of the breach through the request from the AEPD, the Hospital managers had not taken any corrective measures to date.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
38/77

Notwithstanding, and until the scope and consequences of the breach are known, on August 28, the decision has been made to suspend the registration of new (...) in the project ***PROJECT.1. Additionally, an investigation has been opened to assess the extent of what occurred, as well as to proceed to demand accountability.”

-

Attached as Annex 2 is a certificate issued by the Managing Director of ***CENTER.48 dated February 21, 2023, in which it CERTIFIES:

“That it is aware of the proposal made by the Spanish Working Group on Crohn's Disease and Ulcerative Colitis (GETECCU), as promoter, for the RESEARCH PROJECT titled: “(***PROJECT.1)”, which will be carried out in the DIGESTIVE SYSTEM Service by the Principal Investigator E.E.E., who commits to conducting it in accordance with the protocol authorized by the CEIm and the provisions that affect it.

That it accepts the execution of said Research Project in this Center.”

-

Attached as Annex 3 is the consent form provided to the (...). From its analysis, it is confirmed that it is the same model provided by ***CENTER.50, already analyzed in the previous point.

7. Internet Research:

-

On September 10, 2024, this Agency verifies that from the GETECCU website (geteccu.org) the

following information is extracted:

"The registration ***PROJECT.1 aims to promote clinical/genetic studies based on a large number of (...) as well as to offer a common working tool to the members of GETECCU. The two fundamental elements of the project are the database and the biobank. The database has been developed by consensus, presented and discussed in several meetings of the Group, and has the sponsorship of various pharmaceutical companies.

It is a database with different sections that, in addition to contributing to the registration ***PROJECT.1, can be used locally, as a registry of (...), although it was developed with the aim of obtaining selected variables on different aspects of the disease (epidemiological, clinical, drug safety, etc.) for subsequent common exploitation for scientific and translational purposes.

The registration allows the exploitation of the information for the realization of epidemiological, clinical, and genetic studies. To this end, the registration ***PROJECT.1 was approved at the time by the Clinical Research Ethics Committee of ***CENTER.52, and the registration was registered with the Data Protection Agency, ensuring that the use of its information complies with all legal regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/77

To participate in the project ***PROJECT.1 and to benefit from both its scientific production and its utility at the local level, interested centers must obtain the approval of their local Ethics Committee and sign the contract with GETECCU. This will allow the center to be sent the necessary codes to access the website where the database is located."

"The maintenance and exploitation of the registration ***PROJECT.1 depends on the members of the Research area, the Governance area of GETECCU, and the coordinator ***PROJECT.1. The coordinator ***PROJECT.1 is appointed every two years by the Board of GETECCU and is responsible (along with the scientific secretary) for the maintenance and renewal of the registration, as well as ensuring that the established rules (set out in the corresponding PNTs) for the request and approval of projects, transfer of data and biological samples, and drafting of articles derived from the registration ***PROJECT.1 are complied with."

-

On September 10, 2024, this Agency verifies that from the GETECCU website (geteccu.org) the following information is extracted regarding the requirements to participate in the project

***PROJECT.1 (...):

"To use ***PROJECT.1 in a center, it is necessary to have the written authorization signed by the "DATA CONTROLLER" who is the manager (or legal entity responsible) of each hospital. To do this, the data processing agreement document must be completed..."

"The DATA CONTROLLER (manager or legal entity responsible) retains the exclusive right of ownership and use of it, as well as all its updating processes, and requests the provision of the DATA PROCESSOR (GETECCU) which guarantees that all the security conditions established in the aforementioned Data Protection Law are met. The company subcontracted by GETECCU to manage the database is ***COMPANY.1 (...)."

-

On September 10, 2024, this Agency verifies that on the website of the Valencian Society of Hospital Pharmacy, the following document used in a training talk about the project ***PROJECT.1 is obtained (...):

"Who, when, and how can a research project of ***PROJECT.1 be requested?

1. All physicians from the participating centers in ***PROJECT.1 (with authorization from the center's PI)
2. Member of GETECCU
3. For clinical studies, clinical variables of more than 100 (...), and more than 100 DNA samples for genetic studies must have been entered.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
40/77

4. Having the study requested approved by the CEIC of the hospital to which one belongs

5. Completing a form (...)"

It contains multiple screenshots with the data collected and entered into the platform by each researcher, specifically drawing attention to the form for entering the patient's demographic data (page 9 of the document), which includes the following data ("Fields marked with an asterisk (*) are mandatory"): "Name", "First Surname", "Second Surname", "Address", "Postal Code", "City", "Landline Phone", "Mobile Phone", "Medical Record Number", "Date of Birth (dd/mm/yyyy) (*)", "Hospital (*)", "Patient Code (5 digits) (*)", "Patient ID (*)", "Sex (*)".

-

On September 11, 2024, this Agency verifies that, in relation to the reactive measure implemented for token substitution by roles, the ***APP.1 website titled "Recommended Security Best Practices by ***APP.1" incorporates the following text extracted from the official documentation of ***APP.1, which recommends not using access keys directly in the application that needs to access resources of ***EMPRESA.4 (programmatic tokens), instead using ROLES as a good security practice (...): "Use of roles of (...) for Applications and Services of ***APP.1 that require access to ***EMPRESA.4: For applications running on ***EMPRESA.3 or other Services of ***APP.1 to access resources of ***EMPRESA.4, they must include valid ***APP.1 credentials in their requests to the ***APP.1 API. We recommend not storing ***APP.1 credentials directly in the application or in an instance of ***EMPRESA.3. These are long-term credentials that do not rotate automatically and could have a significant business impact if compromised.

Instead, use a ROLE of (...) to temporarily manage credentials for applications or services that need to access ***EMPRESA.4. When using a ROLE, you do not have to distribute long-term credentials (such as a username and password or access keys) to an instance of ***EMPRESA.3 or a service of ***APP.1 like ***APP.2. The ROLE provides temporary permissions that applications can use when making calls to other resources of ***APP.1."

-

On September 16, 2024, this Agency verifies that the following article about the ***PROYECTO.1 project is published in the scientific journal ELSEVIER, titled "****PROYECTO.1 Registry of GETECCU: design, monitoring, and functions" (...), with, among other content, the following:

"The modification of variables has always been carried out at the discretion of a group of experts, which includes members of the research area and the president of the GETECCU board, as well as to C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
41/77

those members of GETECCU that the board designated at each moment.

"To create a new patient record, it is essential to complete the demographic data form, without which the system does not allow the entry of the remaining variables. The patient's identification data is only visible locally for care purposes, and all records are anonymized at the central level. Furthermore, each researcher only has access to the data from their own center."

"Once the Ethics Committee of the participating center has approved the project and its management has signed the agreement with GETECCU in accordance with the regulations regarding data protection and the regulations on clinical trials of human medicines, GETECCU grants the necessary passwords to the principal investigator of the center and to the collaborating researchers to access the registry locally."

-

On September 19, 2024, this Agency verifies that, regarding the processes established in the ISO

27001 standard, in Annex A.10 of this standard, which establishes cryptographic controls to protect information, requirements for encrypting specially protected data, it states: "The cryptographic controls of Annex A.10 are based on the principle of least privilege and require that only authorized persons have access to cryptographic keys and that these keys are properly protected."

-

On September 20, 2024, this Agency verifies that in the official documentation of ***APP.1, regarding "Identity Management" and "Best practices for securely storing and using secrets," at the link (...) the following content can be seen, among others (the underlining is ours):

"A common anti-pattern is embedding access keys of (...) within the source code, configuration files, or mobile applications. When an access key of (...) is required to communicate with a ***APP.1 service, use temporary security credentials (short-term).

These short-term credentials can be provided through roles of (...) for instances of (...), execution roles for functions (...)

, roles of (...) of

(...)

for mobile user access and policies of

(...)

for IoT devices.

When interacting with third parties, it is preferable to delegate access to a role of (...) with the necessary access to your account resources instead of setting up a user of (...) and sending that third party the secret access key for that user."

-

On September 24, 2024, this Agency verifies that in the official documentation of ***APP.1, regarding information on good security practices and recommendations for implementing the National Scheme Level MEDIUM through the configuration of ***APP.1, on the website (...) the following content can be seen, among others (The information is not updated with the latest version of the ENS (RD 311/2022): Related measure of RD 3/2010 (Annex II 4.2.5. Authentication Mechanism, page 27):

"Access to systems and assets can be controlled by checking that the root user does not have access keys attached to their ***APP.1 function (...). Ensure to remove root access keys. Instead, create and use the role-based system Accounts of ***APP.1 to help incorporate the principle of least functionality."

TENTH: According to the report collected from the AXESOR tool on December 15, 2024, the entity GETECCU is an association with a sales volume of (...) euros.

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure, considering the impact of the breach subject to this procedure concerning the hospital centers within the scope of competence of the AEPD.

II

Procedure

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

In accordance with Article 64 of the LOPDGDD, and taking into account the characteristics of the alleged infringements committed, a sanctioning procedure is initiated.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After that period, it will expire, and, in

C/ Jorge Juan, 6

www.aepd.es

As a consequence, the file of proceedings shall be archived, in accordance with the provisions of Article 64 of the LOPDGGDD.

If no allegations are made to this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

III

Preliminary Issues

Processing of Personal Data

On June 19, 2023, GETECCU notified this Agency of a personal data breach, in which the following was reported:

- "Types of affected data: (...)"
- The affected individuals have the following profiles: (...)"

On July 11, 2023, GETECCU submitted to this Agency a written extension of the notification of this breach, in which the following was reported:

- "Types of affected data (...)"

On July 11, 2023, GETECCU received an email response to a previous email from this Agency stating: "These are CSV files with structured data. The affected personal data are: (...)."

In its Document 05.1 accompanying its written response dated February 21, 2024, to the request from this Agency, GETECCU provided a copy of the contract formalized between GETECCU and ***CENTRO.54, dated September 18, 2023, in which Annex I stated:

"Data subject to processing:

- Identifying data of the patient: - Name - Surname - Gender - Date of birth - Phone number - Address.
- Identifying data of the designated physician: - Name - Surname
- Health data: - Symptoms - Diagnosis - Physical condition - Medication."

In its Document 08 accompanying its written response dated February 21, 2024, to the request from this Agency, GETECCU stated: "The types of data affected by the attack were: (...)"

On September 10, 2024, this Agency verified that on the website of the Valencian Society of Hospital Pharmacy, a document used in a training talk about the project ***PROYECTO.1 (...) was obtained, in which multiple screenshots were observed with the data collected and entered into the platform by each researcher. Specifically, in the form for entering the demographic data of the patient (page 9 of the document), the following data is included ("Fields marked with an asterisk (*) are mandatory"): "Name," "First Surname," "Second Surname," "Address," "Postal Code," "City," "Landline Phone," "Mobile Phone," "History Number," "Date of Birth (dd/mm/yyyy) (*)," "Hospital (*)," "Patient Code (5 digits) (*)," "Patient ID (*)," "Gender (*)".

Therefore, in this case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, it is established that GETECCU is processing personal data, as it involves, among other processes, the collection and retention of personal data of individuals: "Name," "First Surname," "Second Surname," "Address," "Postal Code," "City," "Landline Phone," "Mobile Phone," "History Number," "Date of Birth (dd/mm/yyyy) (*)," "Hospital (*)," "Patient Code (5 digits) (*)," "Patient ID (*)," "Gender (*)," as well as clinical data related to the pathology of the (...) participants.

Data Controller

On June 19, 2023, GETECCU notified this Agency of a personal data breach in which GETECCU was identified as the data controller and ***EMPRESA.1 as the data processor involved in the breach.

On July 4, 2023, the Catalan Data Protection Authority (APDCAT) contacted this Agency regarding having received several breach notifications from public hospitals in Catalonia within its jurisdiction, which identified GETECCU as the data processor and ***EMPRESA.1 as the sub-processor.

A document titled "PROJECT ***PROYECTO.1" was attached, containing, among other things, the following content:

"The clinical information of all the (...) will be collected in a common database of the project ***PROYECTO.1. (...)

The participating researchers will have full access to the information generated in the center, including the identification data of the (...).

The researchers responsible for a specific study will have access to the information of the (...) included in the particular study contained in the general database, which will be appropriately anonymized, in which cases will only be identified by the code ***PROYECTO.1."

"The project ***PROYECTO.1 is established around the Spanish Working Group on Crohn's Disease and Ulcerative Colitis (GETECCU), which will appoint the committee responsible for the project ***PROYECTO.1 and will be composed of an odd number of members, which at the discretion of GETECCU will be set at 5 or 7.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/77

The owner, responsible for the database and data processing, is GETECCU.

GETECCU will act as the entity before which the rights of opposition, access, rectification, and cancellation can be exercised.

The database was registered with the data protection agency in 2006, and the registration was updated in 2012 to comply with current law.

The location of the server where clinical information will be stored will be the headquarters of ***EMPRESA.1.

The entity responsible for data processing and samples will be GETECCU.

On July 5, 2023, ***CENTRO.54 (***CENTRO.54) notified this Agency of the personal data breach subject to this procedure, identifying ***CENTRO.54 as the data controller and GETECCU as the data processor involved in the breach.

On July 11, 2023, an email response was received by this Agency from GETECCU, stating:

"Regarding the database ***PROYECTO.1, affected by the Cyberattack, GETECCU is the data controller and ***EMPRESA.1, as the technology provider, the data processor." A PDF file was attached with the communication of the breach that GETECCU made to the medical researchers belonging to the affected hospitals (on June 22, 2023, and July 3, 2023), in which it was stated: "We remind you that, in accordance with Article 33, paragraph 1, of the GDPR, your center, as the data controller/joint controller, must inform the competent supervisory authority of the data breach (no later than 72 hours after becoming aware of it), as there is a potential risk to the rights and freedoms of natural persons."

On August 9, 2023, ***CENTRO.55 notified this Agency of the personal data breach subject to this procedure, identifying ***CENTRO.55 as the data controller and GETECCU as the data processor involved in the breach.

On August 10, 2023, ***CENTRO.54 notified this Agency of an extension of information regarding the reported breach, but ***CENTRO.54 was identified as the data controller and ***EMPRESA.1 as the data processor involved in the breach.

On August 10, 2023, ***CENTRO.1 notified this Agency of the personal data breach subject to this procedure, identifying ***CENTRO.1 as the data controller and GETECCU as the data processor involved in the breach.

On August 17, 2023, ***CENTRO.53 notified this Agency of the personal data breach subject to this procedure, identifying ***CENTRO.53 as the data controller and GETECCU as the data processor involved in the breach.

On August 25, 2023, ***CENTRO.2 notified this Agency of the personal data breach subject to this procedure, identifying ***CENTRO.2 as the data controller and indicating that there is no data

processor involved in the personal data breach.

On February 8, 2024, a document was received from ***CENTRO.54, in response to a request from this Agency, which included as Document 05 the data processing contract signed between ***CENTRO.54 and GETECCU, dated September 18, 2023, which stipulated: “***CENTRO.54, as the data controller, authorizes GETECCU to process personal data on its behalf to the extent necessary to provide the indicated service.”

On February 9, 2023, a document was received from ***CENTRO.3, in response to a request from this Agency, which provided a copy of the contract signed between ***CENTRO.53 and GETECCU, dated March 15, 2018, which authorized the hiring of ***EMPRESA.1 as the provider of the technological platform.

On February 12, 2024, a document was received from ***CENTRO.4, in response to a request from this Agency, containing, among other things, the following content: “After several conversations with the company and other participating hospitals in the project, the document was finally formalized on June 19, 2013, in which it is stated that GETECCU is responsible for the file and, at the same time, would sign a contract with ***EMPRESA.1 as the data processor. Document No. 1 is attached, which is the document signed on June 19, 2013.”

In Clause four of the contract, it was stipulated: “In compliance with the provisions of the previous paragraph, the INITIAL DATA CONTROLLER authorizes by signing this contract the DATA CONTROLLER - DATA PROCESSOR: 1.- The subcontracting of the services of DATA PROCESSING of the ASSIGNED DATA to the entity ***EMPRESA.1. (...)”

Document 1 is attached, which is a copy of the contract dated June 19, 2013, identifying the University Hospital of Burgos as the “Initial Data Controller” and GETECCU as the “Data Controller-Data Processor.”

On February 21, 2024, a document was received from GETECCU, in response to a request from this Agency, which included as document 02 the template that is included when a new contract is formalized between GETECCU and a Hospital Center wishing to join the project ***PROYECTO.1. This document includes the following clarification: “THIS ANNEX MUST BE INCLUDED IN THE AGREEMENT BETWEEN GETECCU AND EACH NEW PARTICIPATING ORGANIZATION IN THE PROJECT.” Additionally, this template includes the following paragraphs:

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
47/77

As Document 05 of the GETECCU submission dated February 21, 2024, the following clarifying information regarding the data protection roles assumed by each entity in the ***PROJECT.1 was provided:

“To participate in the ***PROJECT.1, the interested centers obtain the approval of their local Ethics Committee and sign a contract with GETECCU and the researcher, a medical specialist from the hospital center and an associate of GETECCU. After this, the center accesses the website where the database is located.”

“GETECCU receives anonymized information (not personal data), so it does not process personal data that identifies or makes identifiable natural persons. (...) Therefore, since there is no processing of personal data by processing anonymized information, which falls outside the GDPR, it cannot be understood that there is a data controller or a data processor.

Notwithstanding the above, subsidiarily, in the event that it is understood that there is indeed processing of personal data, and therefore, the figures of the controller and, where applicable, the processor must be applicable, each of the healthcare centers would be the data controller of the personal data, while the role of data processor would fall to GETECCU and that of sub-processor to ***COMPANY.1. It is these healthcare centers that collect the information for their own purposes through the physician who attends to the patient, with the aim of providing them with healthcare assistance and, additionally, secondly, to carry out studies that promote the development of medicine

and a better understanding of diseases and treatments, so that this results in better and more efficient healthcare assistance to them.

...the research is conducted in the healthcare centers themselves, with their own physicians participating as principal investigators, directly conveying to organizations such as GETECCU the instructions on the data to be processed, for what purposes, for how long such data should be retained, and what technical and organizational security measures should be applied, all of which is reflected and recorded in the corresponding data processor contracts in which GETECCU acts as the data processor on behalf of and under the instructions of the healthcare centers, and as sub-processor, its technical provider ***COMPANY.1.

We substantiate the statements made by providing, as an example, the data processor contract signed with the Navarra Health Service. And the contract signed between this same service and ***COMPANY.1.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

48/77

As Document 05.1 of the GETECCU submission dated February 21, 2024, a copy of the data processing agreement formalized between GETECCU and ***CENTER.54, dated September 18, 2023, was provided, in which it was stipulated:

“Through these clauses, the conditions are established that enable GETECCU to process, on behalf of ***CENTER.54 (hereinafter ***CENTER.54), the data personal that arises from the provision of the contracted service.

SPANISH WORKING GROUP ON CROHN'S DISEASE, hereinafter GETECCU, will process personal data for which ***CENTER.54 is responsible, to the extent that execution makes it essential.”

“The processing will consist of providing the following service: Carrying out the ***PROJECT.1, which aims to promote clinical/genetic studies based on a significant volume of (...), as well as offering a common working tool to the members of GETECCU. To this end, it is necessary to develop a database with the aim of obtaining the selected variables on different aspects of the disease (epidemiological, clinical, drug safety, etc.) for subsequent exploitation for scientific purposes, which will last as long as the project.

***CENTER.54, as the data controller, authorizes GETECCU to process personal data on its behalf to the extent that this is necessary to provide the indicated service.”

On April 18, 2024, a second submission was received from GETECCU, in response to a request from this Agency, in which it was stated: “Between ***COMPANY.1 and GETECCU there is a data processing agreement titled "EXHIBIT C: USE OF TECHNOLOGY AND DATA PROCESSING," linked to the ***PROJECT.1, which is attached (Document No. 8), signed by both parties on February 13, 2019. In this Document No. 8, the term USER refers to the center that uses the platform, and PROVIDER refers to ***COMPANY.1:

“Within the scope of this agreement, USER is the sole data controller, and PROVIDER acts as the data processor.

GETECCU is the facilitator of THE_PROJECT and acts as the data processor of the data.

Furthermore, GETECCU is the sole data controller of the ***PROJECT.1 database. PROVIDER will be the data processor of the personal data, owned by USER as the data controller, in accordance with the provisions of the current regulations in this matter in our legal system.”

In the GETECCU submission of April 18, 2024, in response to a request from this Agency, Document No. 9 and Document No. 10 were provided, which are copies of the documents and data processing agreements formalized by GETECCU with 47 healthcare centers, from which the following information is extracted:

(...)

C/ Jorge Juan, 6
www.aepd.es

On September 2, 2024, a document was received from ***CENTRO.50, in response to a request from this Agency, in which it stated that:

[the database of ***PROYECTO.1] "... originates from a record whose owner and responsible party is GETECCU and not ***CENTRO.50 (hereinafter, ***CENTRO.50)."

"From GETECCU's perspective, as defined in Article 2 of its statutes: the primary objective or purpose of the Association is to stimulate the study and research of Inflammatory Bowel Disease and to seek the standardization of clinical-therapeutic criteria in its diagnosis and treatment, for which it proposes:

1. To promote the development of suitable therapeutic means through research at all levels, basic, experimental, clinical, and epidemiological.

2. To seek the coordination of these means in a harmonious and complementary manner.

3. To stimulate the uniformity of criteria for the treatment of inflammatory bowel disease."

Therefore, considering the definition of promoter as stated in Article 2 of Royal Decree 1090/2015, of December 4, which regulates clinical trials with medicines, as: 'Individual, company, institution, or organization responsible for initiating, managing, and organizing the funding of a clinical trial,' it can be considered that GETECCU holds the status of research promoter for this Project."

"In accordance, since GETECCU acts as a promoter, following the criteria established by the AEPD itself in both legal report N/REF: 0004/2022 and report N/REF: 0038/2021, the following conclusion is reached:

The promoter is responsible for the processing of data for clinical purposes with medicines, having to make decisions regarding the purposes and means in accordance with the provisions of Regulation (EU) 536/2014 and Royal Decree 1090/2015 that have been outlined."

Provisions that are specifically applicable in relation to the references for this mode of research as stated in Article 16.3 of the LAP when it contemplates the uses of the medical history for research purposes."

"The healthcare center is responsible for the processing of data from the medical history under the terms established in the LAP and the regional regulations governing this matter for the purposes provided in said regulations; except in relation to the uses of the same for health research purposes in the modality of clinical trials which, as noted, are governed by the terms provided in the Royal Decree on clinical trials with medicines. According to the provisions of this regulation, its intervention as the data controller is limited to the authorization for access to the medical history of the trial subject by personnel contracted by third parties, such as the monitor or the CRO. Access may be arranged through a document other than a contract and the figure of the data processor."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/77

treatment, in which specific guarantees for the performance of their functions are established.

Thus, from the reiterated doctrine of this AEPD, it follows that the Hospital (independently from the Promoter) only acts as the data controller of the clinical history data that may be used in the research. In this case, the Center, as the controller of the aforementioned clinical history data, has carried out the necessary analyses and established the corresponding security measures for the proper processing of such information.

In this same sense, the aforementioned Code of Conduct determines that: 'Thus, to the extent that the Promoter determines the criteria for the participants whose coded data must be included in the Clinical Research Database (CRD), it will be considered the data controller of such data, with the Center (and/or, where applicable, the Principal Investigator) being the data controller of the participants' data in the clinical research for the purpose of carrying out the appropriate healthcare assistance to them within the framework and development of the research.'

“...it is evident that in this case GETECCU determines the purposes and means of processing the personal data of the participants in the development of the Project ***PROJECT.1, being responsible for the processing of the personal data included in that database.”

“In relation to the role played by ***CENTER.50 in this Project, and considering that GETECCU is the data controller of ***PROJECT.1, it is important to note that the Center has only limited itself to authorizing, regarding the requesting researcher, access to the clinical histories of their (...), not intervening in any subsequent phase of the study. This has been done with the purpose of allowing the researcher to transfer the relevant information to the database of ***PROJECT.1, a project in which the professional participates independently of the Hospital. Without GETECCU acting in any case as a data processor of the Center, since it does not carry out any activity on behalf of the Hospital regarding the personal data collected in the database ***PROJECT.1, which is the subject of the breach that gives rise to this request.”

“With respect to the transfer of special category data (HC) that is made to the researchers who request it, it should be understood that such transfer is legitimized in accordance with the provisions of Article 6.1 c) of the GDPR, in connection with the provisions of Article 9.2 i) ‘the processing is necessary for reasons of public interest in the area of public health’...and Article 9.2.j) ‘the processing is necessary for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes, in accordance with Article 89, paragraph 1, based on Union or Member State law, which must be proportional to the objective pursued, respect essentially the right to data protection, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject.’

“...the Hospital acts in accordance with current regulations, authorizing access to the clinical histories of its (...) exclusively so that the researcher can fulfill the scientific and research purposes of the Project ***PROJECT.1.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/77

“...in support of this argument, we must point out that, although the Center has given its consent for the study to be conducted on its premises and has authorized access to the data of the (...) involved, the researchers who wish to access and include that information in the database of

***PROJECT.1

must first obtain the informed consent of said (...) for the processing of their data and its possible communication to third parties.”

Annex I includes a document sent from the Legal Office of the Hospital to a researcher from the center itself, in August 2012, highlighting the following text (the underlining is ours):

“The ***PROJECT.1 project is a study that aims to identify genetic and environmental determinants that affect inflammatory bowel disease (...) The study begins with the identification of each subject sample through clinical (care) contact and will rely on two tools: Biobank and Database, with the latter being a fundamental tool where all personal and health data of (...) samples and their surrounding individuals will be recorded, when applicable. The database will be constructed without dissociation. There will also be no dissociation in the use of the medical history of the sample subjects who consent to participate in the project. (...)

The person responsible for the Project database is not the Management of each participating center. (...)

The Management must limit its scope of action to issuing authorization for participation to the professionals of the Public Entity and the Public Entity itself in the ***PROJECT.1 project. Such authorization, combined with the consents that each patient individually provides (...), is sufficient.”

On September 10, 2024, this Agency verified that the following information was available on the GETECCU website (geteccu.org):

“The ***PROJECT.1 registry aims to promote clinical/genetic studies based on a large number of (...)

as well as provide a common working tool for the members of GETECCU. (...)

It is a database with different sections that, in addition to contributing to the ***PROJECT.1 registry, can be used locally as a registry of (...), although it was developed with the purpose of obtaining selected variables on different aspects of the disease (epidemiological, clinical, drug safety, etc.) for subsequent common exploitation for scientific and translational purposes.

The registry allows the exploitation of information for conducting epidemiological, clinical, and genetic studies. (...)

To participate in the ***PROJECT.1 project and benefit from both its scientific production and its utility at the local level, interested centers must obtain approval from their

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/77

Local Ethical Committee and sign the contract with GETECCU. This will allow the necessary codes to be sent to the center to access the webpage where the database is located."

"The maintenance and operation of the ***PROJECT.1 registry depend on the members of the Research area, the Governance area of GETECCU, and the coordinator of ***PROJECT.1. The coordinator of ***PROJECT.1 is appointed every two years by the Board of GETECCU and is responsible (along with the scientific secretary) for the maintenance and renewal of the registry, as well as ensuring compliance with the established rules (set forth in the corresponding PNTs) for the application and approval of projects, transfer of data and biological samples, and drafting of articles derived from the ***PROJECT.1 registry."

On September 10, 2024, this Agency verified that the following was published on the GETECCU website (...):

"For the use of ***PROJECT.1 in a center, it is necessary to have the written authorization signed by the 'DATA CONTROLLER,' who is the manager (or legal entity responsible) of each hospital. To do this, the data processing agreement document must be completed..."

"The DATA CONTROLLER (manager or legal entity responsible) retains the exclusive right of ownership and use of the same, as well as all its updating processes, and requests the service of the DATA PROCESSOR (GETECCU) which guarantees that all security conditions established in the aforementioned Data Protection Law are met. The company subcontracted by GETECCU to manage the database is ***COMPANY.1 (...)."

From all of the above, it is inferred that in the contract signed between GETECCU and ***COMPANY.1, GETECCU is identified as the data controller regarding the data of Project ***PROJECT.1 and ***COMPANY.1 as the data processor. This same relationship is reflected in the notifications of the personal data breach to this Agency, made by GETECCU.

However, in the notifications of the personal data breach reported by the various hospital centers, they identify themselves as the data controllers, while GETECCU is identified as the data processor, except in the second notification made by ***CENTER.54, which identifies ***COMPANY.1 as the data processor, and in the case of ***CENTER.2, which indicates that there is no data processor involved in the personal data breach.

Regarding the participating hospital centers in Project ***PROJECT.1:

- There are signed contracts between the hospital centers as data controllers and the company ***COMPANY.2 (as data processor).
- There are contracts of engagement between the hospital centers as "Initial Data Controller" and GETECCU as "Data Controller."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/77

Data Processor"), in which ***COMPANY.2 is authorized to be contracted as a sub-processor.

☐

There is a signed contract between the hospital center and GETECCU, in which the roles are not specified but the subcontracting of ***COMPANY.1 is authorized and it is stipulated: "Within the scope of this agreement, HOSPITAL will remain the responsible owner of the hospital management and medical care files. GETECCU is the owner of the file ***PROJECT.1, as well as the data processor of the same and facilitator of the project ***PROJECT.1."

☐

There is a signed contract between the hospital center, a research physician, and GETECCU (defined as Promoter), in which the subcontracting of ***COMPANY.2 is authorized, which assumes the role of data processor and stipulates: "The subcontractors, who also have the status of data processors, will also be obliged to comply with the obligations established for the promoter. The promoter will be liable to the CENTER for any non-compliance by the subcontracted entities."

☐

There is a contract between the hospital center and GETECCU, in which it is stipulated: "GETECCU, owner of the file ***PROJECT.1, not possessing the necessary technical means, has contracted the services of a technological provider that ensures the preservation and integrity and will adopt all security measures to prevent any misuse or fraudulent use of computer files used or developed. All terms related to the use of technology and data processing are included in Annex A."

"Within the framework of this agreement, HOSPITAL will remain the responsible owner of the hospital management and medical care files. GETECCU is the owner of the file ***PROJECT.1, as well as the data processor and facilitator of the project ***PROJECT.1."

"GETECCU has contracted the platform from ***COMPANY.1 which will make all efforts to ensure the preservation and integrity of the documents and/or information and will adopt all measures to prevent any misuse or fraudulent use of computer files used within the framework of the agreement."

☐

There are signed contracts between the hospital centers, a research physician, and GETECCU (defined as Promoter), in which the subcontracting of ***COMPANY.2 is authorized, which assumes the role of data processor.

☐

There are service contracts between the hospital centers as data controllers and GETECCU as processor, in which the subcontracting of ***COMPANY.2 is authorized, which assumes the role of data processor of the data.

☐

There is a service contract between the hospital center as data controller and GETECCU as processor, in which the subcontracting for the use of the platform of ***COMPANY.1 is authorized.

☐

There is a signed contract between the hospital center and GETECCU in which it is stipulated:

"EIGHTH: Protection of Personal Data:

"The Researcher will treat the participants' data as indicated in the Protocol. Only the persons indicated in the information sheet and in the informed consent will have access to the personal data of the subjects."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/77

"The Promoter will ensure that the personal data contained in the documentation related to the study has been collected in accordance with applicable regulations, providing the necessary information, expressly informing about the destination of the data, and obtaining consent from the data subjects."

"The data controller (by the Center) is (...), (by the managing entity) (...), (by the Promoter)

GETECCU."

- There is a signed contract between the hospital center and GETECCU which stipulates: "The file or

files of personal data will be provided by the HOSPITAL to GETECCU, at all times the center retains the exclusive right of ownership and use of the same, as well as all its updating processes. GETECCU will process the personal data provided by the HOSPITAL in accordance with the instructions given by it, and for the purposes and uses exclusively necessary for the development of the services detailed in this contract, and may not use it for any other purpose." And subcontracting to ***EMPRESA.2 is authorized, which acts as the data processor.

- There is a signed contract between the hospital center and GETECCU, in which the roles are not specified, but the hiring of "the services of a technology provider for hosting and IT support" is authorized.

- There is a document in which the hospital center accepts the execution of the Project, but the roles are not specified.

As can be seen, there are discrepancies in all the information contained in this procedure regarding the roles of the hospital centers, GETECCU, and ***EMPRESA.2 / ***EMPRESA.1 concerning the processing of personal data subject to Project ***PROYECTO.1.

According to the Guidelines 07/2020 of the EDPB on the concepts of "Data Controller" and "Data Processor" in the GDPR, the concepts of data controller and data processor are functional concepts, and it is necessary to establish them based on their specific activities in the analyzed case and not based on the formal designation that may appear in the contract: "12. The concepts of 'data controller' and 'data processor' are functional concepts: their purpose is to assign responsibilities based on the actual role of each party. This implies that the legal status of 'data controller' or 'data processor' of the participants must be established primarily based on their specific activities in a given situation and not based on the formal designation of a participant as 'data controller' or 'data processor' (e.g., in a contract). This implies that the assignment of the role of controller or processor should normally derive from an analysis of the facts or circumstances of the case and, consequently, is not negotiable."

Furthermore, the aforementioned EDPB Guidelines 07/2020 advocate for a broad interpretation of the concept of data controller in order to promote effective and comprehensive protection of data subjects. In this regard, they provide: "14. Since the ultimate goal of assigning the role of data controller is to ensure proactive accountability and effective and comprehensive protection of data."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/77

In relation to personal data, the concept of "controller" should be interpreted broadly enough to promote, as far as possible, effective and comprehensive protection of the data subjects, in order to ensure the full effectiveness of Union law regarding data protection, avoid gaps, and prevent possible circumventions of the regulations, without this implying a reduction of the powers of the processor."

In addition to what has already been stated, it should be noted that these Guidelines from the EDPB highlight: "20. (...) The controller is the entity that decides on certain essential aspects of the data processing. The responsibility for processing can be established in the regulations or inferred from an analysis of the facts or circumstances of the case. It is necessary to focus on the specific processing activities in question and understand who determines them. To do this, the following questions must first be examined: 'Why is the processing taking place?' and 'Who has decided that the processing should be carried out for a specific purpose?'"

In relation to this issue, the EDPB Guidelines 07/2020 have emphasized that the terms of a contract are not determinative when establishing which party acts as the controller, and it is necessary to analyze the circumstances of the specific case: "28. In many cases, examining the contractual clauses between the various parties involved can help determine which party or parties act as the controller. Even if the contract does not stipulate who the controller is, it may contain sufficient elements to infer who has the decision-making power regarding the purposes and means of the processing. It is also possible that the contract contains an express statement about the identity of the controller. If there are no reasons to doubt that this aligns with reality, there is nothing to prevent following the conditions set out in the contract. However, the terms of a contract are not determinative in all cases, as, if that were

the case, the parties could simply attribute responsibility as they saw fit. It is not possible to become a controller or evade the obligations of the controller through a mere formula in the contract when the factual circumstances indicate otherwise."

Section 7 of Article 4 "Definitions" of the GDPR indicates that the controller is "the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing..."

The EDPB Guidelines 07/2020 indicate two fundamental conditions to be considered a processor:

"76. To be considered a processor, two fundamental conditions must be met:

- a) being an independent entity from the controller; and
- b) processing personal data on behalf of the controller."

In this regard, this Agency considers that, although the incident that originated this procedure took place in the systems of ***COMPANY.1, GETECCU acts in this case as the controller of the personal data affected by the breach in question (data from Project ***PROJECT.1, given that:

- GETECCU notified the breach to this Agency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/77

- GETECCU reported the breach through its website

- GETECCU informed the affected hospitals about the breach

- On the main platform through which data is submitted by users (doctors from participating hospitals), the project logo and GETECCU letterhead are displayed for logging in, as well as on the form to be completed. Therefore, GETECCU is the entity that identifies the data to be provided by the participants in the project.

- A data processing agreement was signed, in which GETECCU is identified as the data controller and ***COMPANY.1 as the processor.

- There is an Annex document included in the agreements signed between GETECCU and the hospital centers participating in Project ***PROJECT.1, thus determining the technological clauses and personal data processing that would apply to the participating entities. Furthermore, the following conclusions can be drawn from this document:

- o Section 2.12. Personal data:

- "GETECCU is the sole responsible party for the processing of the database ***PROJECT.1." While the hospital centers are responsible for the processing of the data they incorporate into the Project, GETECCU is responsible for all data incorporated into the database of the Project in question, which was affected by the breach subject to this procedure.

- o "GETECCU has contracted the platform (...) from PROVIDER." That is, GETECCU is the one who decides on the purposes (the characteristics of the project are set by GETECCU, and the hospital centers adhere to them; that is, they cannot establish particularities regarding the data or objectives of the study, but rather adhere to what has already been determined by GETECCU) and means of processing.

Finally, this Agency wishes to bring to attention the arguments put forth by ***CENTER.50 in its letter dated September 2, 2024, in which it considers that GETECCU acts as the data controller regarding the personal data of Project ***PROJECT.1, especially concerning the criteria established by the AEPD in its legal reports N/REF: 0004/2022 and N/REF: 0038/2021, understanding that GETECCU is considered the promoter of the research of Project ***PROJECT.1, so that even if it did not access the personal data included in the database, it remains the data controller of such data.

Indeed, GETECCU aims to stimulate the study and research of Inflammatory Bowel Disease and to seek the standardization of clinical-therapeutic criteria in its diagnosis and treatment. In this case, GETECCU has promoted and coordinated the execution of Project ***PROJECT.1.

Article 2 of Royal Decree 1090/2015, of December 4, which regulates clinical trials with medicines, defines the promoter as: 'Individual, company, institution, or organization responsible for initiating, managing, and organizing the financing of a clinical trial,' therefore this Agency understands that in this

case GETECCU holds the status of research promoter for Project.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

57/77

***PROJECT.1, whose personal data was affected by the breach subject to the present procedure.

In legal reports N/REF: 0004/2022 and N/REF: 0038/2021, this Agency has understood that the promoter is responsible for the processing of data for clinical purposes with medications, having to make decisions regarding the purposes and means in accordance with the provisions of Regulation (EU) 536/2014 and Royal Decree 1090/2015.

And that the healthcare center is responsible for the processing of clinical history data under the terms established in the LAP and regional regulations governing this matter with the purposes provided for in said regulations; except regarding the uses of the same for health research purposes in the modality of clinical trials which, as noted, are governed by the terms provided in the Royal Decree on clinical trials with medications. According to the provisions of this regulation, its intervention as the data controller is limited to the authorization for access to the clinical history of the trial subject by personnel contracted by third parties, such as the monitor or the CRO. Access may be arranged through a document distinct from a contract and from the figure of the data processor, in which specific guarantees for the performance of their functions are established.

Therefore, hospital centers only act as data controllers of the clinical history data that may be used in research.

In light of the above, in this case, this Agency understands that GETECCU is the one who determines the purposes and means of processing the personal data of the participants in Project ***PROJECT.1, being the promoter of the project in question, and therefore is responsible for the processing of the personal data included in said database, which was affected by the personal data breach that gave rise to the present procedure.

Thus, this Agency concludes that GETECCU processes personal data within the framework of Project ***PROJECT.1 in its capacity as data controller, given that it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

IV

Unfulfilled obligation. Integrity and confidentiality

Letter f) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

58/77

Loss of confidentiality of personal data

On June 19, 2023, GETECCU notified this Agency of a personal data breach in which it reported that there had been "Unauthorized access to files of the secondary storage system with deletion and possible download of the same."

In light of the above, this Agency understands that there has been a loss of confidentiality of the personal data linked to Project ***PROJECT.1.

Affected personal data

On June 19, 2023, GETECCU notified this Agency of a personal data breach in which it reported that

the following personal data of (...): (...) had been affected. In its extension of the breach notification dated July 11, 2023, GETECCU indicated that the aforementioned breach affected (...) individuals. On July 11, 2023, an email response was received by this Agency from GETECCU stating: "These are CSV files with structured data. The affected personal data are: (...).

In its document dated February 21, 2024, GETECCU provided as document 05.1 a copy of the contract formalized between GETECCU and ***CENTER.54, dated September 18, 2023, in which Annex I states:

"Data subject to processing:

- Identifying data of the patient: - Name - Surname - Gender - Date of birth - Phone number - Address.
- Identifying data of the designated physician: - Name - Surname
- Health data: - Symptoms - Diagnosis - Physical condition - Medication."

In its document dated February 21, 2024, GETECCU attached as document 08 a list of the types of data affected by the leak, in which they state:

"The types of data affected by the attack were:

(...)

On September 10, 2024, this Agency verifies that on the website of the Valencian Society of Hospital Pharmacy, the following document used in a training talk about Project ***PROJECT.1 is obtained:

"Who, when, and how can a research project of ***PROJECT.1 be requested?

1. All physicians from the participating centers in ***PROJECT.1 (with authorization from the center's PI)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

59/77

2. Partner of GETECCU

3. For clinical studies, clinical variables of more than 100 (...) must have been introduced, and more than 100 DNA samples for genetic studies.

4. The study requested must be approved by the CEIC of the Hospital to which one belongs.

5. Complete a form (...)"

It contains multiple screenshots with the data collected and entered into the platform by each researcher, specifically drawing attention to the form for entering the patient's demographic data (page 9 of the document), which includes the following data ("Fields marked with an asterisk (*) are mandatory"): "Name", "First Surname", "Second Surname", "Address", "Postal Code", "City", "Landline Phone", "Mobile Phone", "History Number", "Date of Birth (dd/mm/yyyy) (*)", "Hospital (*)", "Patient Code (5 digits) (*)", "Patient ID (*)", "Sex (*)".

For all the above, this Agency understands that the following personal data of (...) natural persons would have been affected by the breach subject to this procedure: (...). These latter data are included in Article 9 "Processing of special categories of personal data" of the GDPR, according to which: "1. The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data aimed at uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation is prohibited."

Chronology of events and technical or organizational measures

Along with the breach notification extension dated July 11, 2023, GETECCU submitted an expert report, dated July 5, 2023, prepared by ***ORGANISMO.1, which explained that on June 14, 2023, ***EMPRESA.1 detected (...).

The report explains that ***EMPRESA.1 (...).

Regarding the chronology of events, (...).

The attack occurred due to (...)."

The aforementioned expert report lists a series of technical recommendations to improve the platform of ***EMPRESA.1, among which stand out: (...).

The report also details improvements implemented by ***EMPRESA.1, regarding (...), among others. It

also outlines other measures that were underway or about to begin, among which stand out: (...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

60/77

In its letter dated February 21, 2024, GETECCU attaches as Document 06 the risk analysis for the affected processing activity, including the activity “Development of Scientific Research Projects in Collaboration with Hospital and Health Centers.” In its section on “Security of processing,” the element “There is unauthorized access to personal data” is assigned a probability degree of “Unlikely,” an impact of “Very significant,” and a risk of “Very high.”

The document concludes: “After evaluating the risk considering the likelihood of the realization of the detected threats and the impact that such realization would have, it has been estimated that the average risk level of the processing, taking into account the personal data processed, the context, and the environment is MEDIUM, for which legal, technical, and organizational measures have been applied, so that the risk level, while not high, has been mitigated.

In its letter dated February 21, 2024, GETECCU attaches as Document 7 the procedure implemented in GETECCU for managing security breaches, although it contains neither signature nor date of creation or update. Its content includes information about the channels for reporting incidents and the notification obligations to both AEPD and affected parties. However, it does not incorporate information about tasks, roles, and responsible persons for carrying them out.

In its letter dated February 21, 2024, GETECCU attaches as Document 10 statements provided by ***EMPRESA.1 clarifying several points of the expert report. This document explains: “(...)”.

It is stated that it was decided to replace programmatic tokens with roles and implement a second encryption system in the secondary storage system (this new functionality would have been implemented since July 2023).

In its letter dated February 21, 2024, GETECCU attaches a document from ***EMPRESA.1 titled “NEW TECHNICAL AND ORGANIZATIONAL MEASURES ADOPTED BY ***EMPRESA.1 TO AVOID, AS MUCH AS POSSIBLE, SECURITY INCIDENTS LIKE THE ONE THAT OCCURRED,” in which it is indicated that (...).

On April 18, 2024, a second letter was received from GETECCU, in response to a request from this Agency, in which Document No. 8 was attached, the contract template between GETECCU and the hospital centers, “EXHIBIT C: USE OF TECHNOLOGY AND DATA PROCESSING,” in which it stipulates:

- (...)

- The contract includes a descriptive table with the controls and security measures to be implemented by the data processor (the underlining is ours):

(...)

For its part, on September 11, 2024, this Agency verifies that, regarding the reactive measure implemented of replacing tokens with roles, on the ***APP.1 website titled “Best Security Practices Recommended by ***APP.1,” the following text extracted from the official documentation of ***APP.1 is included, in which it (...).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

61/77

On September 19, 2024, this Agency verifies that, with respect to the processes established in the ISO 27001 standard, in Annex A.10 of this standard, which establishes the cryptographic controls to protect information, requirements for encrypting specially protected data, it is stated: “The cryptographic controls of Annex A.10 are based on the principle of least privilege and require that only authorized persons have access to cryptographic keys and that these keys are properly protected.”

On September 20, 2024, this Agency verifies that in the official documentation of ***APP.1, in relation to "Identity Management" and "Best practices for securely storing and using secrets," the following content can be seen at the link (...) (the underlining is ours):

"A common anti-pattern is embedding access keys of (...) within the source code, configuration files, or mobile applications.

When an access key of (...) is required to communicate with a ***APP.1 service, use temporary security credentials (short-term).

These short-term credentials can be provided through (...) roles for instances of (...), execution roles for functions (...), roles of (...) for mobile user access, and policies of (...) for IoT devices.

When interacting with third parties, it is preferable to delegate access to a (...) role with the necessary access to your account resources instead of setting up a (...) user and sending that third party the secret access key for that user."

On September 24, 2024, this Agency verifies that in the official documentation of ***APP.1, regarding information on best security practices and recommendations for implementing the National Scheme Level MEDIUM through the configuration of ***APP.1, on the website (...) the following content can be seen, among others (The information is not updated with the latest version of the ENS (RD 311/2022): Related measure of RD 3/2010 (Annex II 4.2.5. Authentication Mechanism, page 27):

"Access to systems and assets can be controlled by checking that the root user does not have access keys attached to their ***APP.1 function (...). Ensure that root access keys are removed. Instead, create and use the role-based system Accounts of ***APP.1 to help incorporate the principle of least functionality."

In conclusion, the fact that ***EMPRESA.1 (data processor) did not have the measures that have been examined in place allowed the personal data breach to occur and its greater impact. The aforementioned measures were introduced by the data processor subsequently (reactively), in order to prevent a similar personal data breach from occurring again.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

62/77

By virtue of Article 4.8 of the GDPR, the data processor is the one who "processes personal data on behalf of the data controller."

For all the above reasons, this Agency understands that the confidentiality of the personal data of Project ***PROYECTO.1 was compromised because GETECCU, as the data controller, did not have the appropriate technical or organizational measures in place to prevent an incident like the one that occurred.

Therefore, in accordance with the evidence available at this time regarding the initiation of sanctioning proceedings, it is considered that the known facts could constitute an infringement attributable to GETECCU for violation of Article 5.1.f) of the GDPR.

V

Classification of the infringement of Article 5.1.f) of the GDPR and qualification for the purposes of prescription

Article 83.5 of the GDPR classifies as an administrative infringement the violation of the following articles, which will be sanctioned, according to paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purpose of the prescription period, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe in three years the infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

VI

Proposal for sanction for the infringement of Article 5.1.f) of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

63/77

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation specified in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD provides:

"1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) To have, when not mandatory, a data protection officer.
- h) The voluntary submission by the responsible party or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.

In the present case, considering the severity of the possible infringements, particularly taking into account the consequences that their commission causes to the affected parties, the imposition of a fine would be appropriate.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the sales volume of GETECCU ((...) euros) is considered as a preliminary factor.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to grade the sanction to be imposed according to the following circumstances, as contemplated in the aforementioned provisions.

As a preliminary matter, it is estimated that the following circumstances are present:

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the data processing operation in question as well as the number of affected parties and the level of damage and harm suffered by (...) individuals, due to the lack of appropriate technical or organizational measures for an incident such as the one that gave rise to this procedure.

- The categories of personal data affected by the infringement (Article 83.2, letter g), of the GDPR):

Among the data affected by the breach, there were health data of the (...) participants in Project ***PROJECT.1.

Furthermore, the following aggravating factors are considered for grading:

- The link of the infringer's activity with the processing of personal data (Article 76.2, letter b), of the LOPDGDD): GETECCU is an organization dedicated to collecting health data on a specific pathology, and is therefore accustomed to processing personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions in the

Article 5.1.f) of the GDPR allows for an initial administrative fine of €10,000.00.

VII

Breach of obligation. Data Processor

The provisions regarding the data processor are set out in Article 28 of the GDPR, which stipulates the following:

- "1. When processing is to be carried out on behalf of a data controller, the controller shall choose only a processor that provides sufficient guarantees to implement appropriate technical and organizational measures, in such a way that the processing will be in compliance with the requirements of this Regulation and will ensure the protection of the rights of the data subject.
2. The processor shall not engage another processor without the prior written authorization, specific or general, of the controller. In the latter case, the processor shall inform the controller of any intended changes concerning the addition or replacement of other processors, thereby giving the controller the opportunity to object to such changes.
3. The processing by the processor shall be governed by a contract or other legal act under Union or Member State law, which binds the processor to the controller and establishes the subject matter, duration, nature, and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller. Such contract or legal act shall stipulate, in

particular, that the processor:

- a) shall process the personal data only on documented instructions from the controller, including with regard to transfers of personal data to a third country or an international organization, unless required to do so by Union or Member State law applicable to the processor; in such a case, the processor shall inform the controller of that legal requirement before processing, unless that law prohibits such information on important grounds of public interest;
- b) shall ensure that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;
- c) shall take all necessary measures in accordance with Article 32;
- d) shall respect the conditions laid down in paragraphs 2 and 4 for engaging another processor;
- e) shall assist the controller, taking into account the nature of the processing, by means of appropriate technical and organizational measures, insofar as this is possible, for the controller to fulfill its obligation to respond to requests for exercising the rights of data subjects laid down in Chapter III;
- f) shall assist the controller in ensuring compliance with the obligations laid down in Articles 32 to 36, taking into account the nature of the processing and the information available to the processor;
- g) at the choice of the controller, shall delete or return all personal data after the end of the provision of processing services, and shall delete the copies."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

66/77

existing unless the retention of personal data is required under Union or Member State law;

h) will provide the controller with all necessary information to demonstrate compliance with the obligations set out in this article, as well as to enable and contribute to audits, including inspections, by the controller or another auditor authorized by the controller.

In relation to the provisions of point h) of the first paragraph, the processor shall immediately inform the controller if, in its opinion, an instruction infringes this Regulation or other provisions on data protection of the Union or the Member States.

4. When a processor engages another processor to carry out specific processing activities on behalf of the controller, the same data protection obligations as those stipulated in the contract or other legal act between the controller and the processor referred to in paragraph 3 shall be imposed on this other processor, through a contract or other legal act established in accordance with Union or Member State law, in particular the provision of sufficient guarantees for the application of appropriate technical and organizational measures so that the processing is in compliance with the provisions of this Regulation. If that other processor fails to comply with its data protection obligations, the initial processor shall remain fully liable to the controller for compliance with the obligations of the other processor.

5. The adherence of the processor to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may be used as an element to demonstrate the existence of the sufficient guarantees referred to in paragraphs 1 and 4 of this article.

6. Without prejudice to the fact that the controller and the processor enter into an individual contract, the contract or other legal act referred to in paragraphs 3 and 4 of this article may be based, in whole or in part, on the standard contractual clauses referred to in paragraphs 7 and 8 of this article, even when they form part of a certification granted to the controller or processor in accordance with Articles 42 and 43.

7. The Commission may establish standard contractual clauses for the matters referred to in paragraphs 3 and 4 of this article, in accordance with the examination procedure referred to in Article 93, paragraph 2.

8. A supervisory authority may adopt standard contractual clauses for the matters referred to in paragraphs 3 and 4 of this article, in accordance with the consistency mechanism referred to in Article 63.

9. The contract or other legal act referred to in paragraphs 3 and 4 shall be in writing, including in electronic format.

10. Without prejudice to the provisions of Articles 82, 83, and 84, if a processor infringes this Regulation by determining the purposes and means of the processing...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

67/77

treatment, will be considered responsible for the treatment with respect to said treatment."

As detailed in the Legal Basis III of this document, to which we refer for brevity, in the notifications of the present breach to this Agency, GETECCU identified itself as the data controller, but so did the hospital centers that reported the incident. And in these latter notifications, there were discrepancies regarding whether there was any data processor involved in the breach, and whether it was GETECCU or ***COMPANY.1.

Regarding the documents signed by the hospital centers, in almost all of them they were considered data controllers. Some contracts were signed directly with ***COMPANY.2 / ***COMPANY.1 as data processor. Others were signed with GETECCU as data processor and ***COMPANY.1 was identified as sub-processor. In others, the hospital centers were identified as "Initial Data Controller," GETECCU as "Data Controller - Data Processor," and ***COMPANY.2 as sub-processor. And in other cases, there was no signed contract, but a document by which the center agreed to participate in the Project. In accordance with the Guidelines 07/2020 of the EDPB on the concepts of "Data Controller" and "Data Processor" in the GDPR, this Agency analyzed the reality of the facts to clarify the true role of each of the entities participating in the aforementioned Project and concluded that GETECCU was actually the data controller of the database of Project ***PROJECT.1, while the hospital centers and ***COMPANY.1 act as data processors.

However, in the documents governing the relationships between the hospital centers and GETECCU, this is not reflected, and consequently, the aspects required by Article 28.3 of the GDPR are not included.

The erroneous attribution of the roles of data controller and data processor implies a lack of clear assignment of responsibilities between both figures, preventing the data controller from fulfilling the obligations imposed by the GDPR to ensure the proper protection of the personal data processed on its behalf in relation to the control of the delivery process it carries out.

On the other hand, from the perspective of the data subjects whose data is being processed, this omission also has consequences: the contract between the data controller and its processor is an element that not only legally articulates the relationship between two parties (data controller and data processor) but also serves as a guarantee of the rights and freedoms of the data subjects.

In this sense, the data processing contract must provide, among other aspects, that:

- The data shall only be processed following the documented instructions of the data controller. This implies a double guarantee for the data subjects: the existence of documented instructions from the controller and the obligation of the processor to process the personal data following those instructions.
- The employees of the processor who process the personal data of the data subjects must respect confidentiality.
- The processor must adopt all necessary measures in accordance with Article 32 of the GDPR.
- The data processor may not engage another processor without the prior written authorization, specific or general, of the controller.
- The processor has the obligation to delete or return the personal data to the controller once the provision of the processing services has concluded, and to delete existing copies unless the retention of the personal data is required by Union or Member State law.

In conclusion, this contract regulates and orders how the relationship between the controller and its data processor will develop with the clear objective of providing adequate protection of the rights and freedoms of the data subjects whose data is being processed. This has not occurred in the relationships governing between GETECCU and the hospital centers that are part of Project ***PROJECT.1.

Therefore, in accordance with the evidence available at this moment of the initiation of the sanctioning

procedure, it is considered that the known facts could constitute an infringement, attributable to GETECCU, for violation of Article 28 of the GDPR.

VIII

Classification of the infringement of Article 28 of the GDPR and qualification for the purposes of prescription

Article 83.4 of the GDPR classifies as an administrative infringement the violation of the following articles, which shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

69/77

For the sole purposes of the statute of limitations, Article 73 of the LOPDGDD establishes the following:

"In accordance with what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a two-year statute of limitations, particularly the following: (...)

k) Entrusting the processing of data to a third party without the prior formalization of a contract or other written legal act containing the requirements set forth in Article 28.3 of Regulation (EU) 2016/679."

IX

Proposal for Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;

d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;

e) any previous infringement committed by the controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;

- j) adherence to codes of conduct pursuant to Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 "Sanctions and Corrective Measures" of the LOPDGDD provides:

"1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject."

In this case, considering the severity of the possible infringements, particularly the consequences that their commission causes to the affected parties, the imposition of a fine, in addition to the adoption of measures, if appropriate, would be warranted.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the sales volume of GETECCU ((...) euros) is considered in advance.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence currently available in this initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to graduate the sanction to be imposed according to the following circumstances, as contemplated in the aforementioned provisions.

It is estimated that the following circumstances are present:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

71/77

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damages they have suffered (Article 83.2, letter a), of the GDPR): due to the lack of documents governing the relationship between GETECCU and the hospital centers containing the information required by Article 28 of the GDPR, which affects at least (...) individuals to date.

- The categories of personal data affected by the infringement (Article 83.2, letter g), of the GDPR): the data subject to processing are health data of the (...) participants in the Project ***PROJECT.1.

Furthermore, the following aggravating factors are considered:

- The connection of the infringer's activity with the processing of personal data (Article 76.2, letter b), of the LOPDGDD): GETECCU is an organization dedicated to collecting health data on a specific pathology, and is therefore accustomed to processing personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 28 of the GDPR, initially allows for the imposition of an administrative fine of €7,000.00.

X

Corrective Measures

If the infringement is confirmed, the resolution issued may establish the corrective measures that the infringing entity must adopt to remedy the non-compliance with personal data protection legislation, in this case, Article 28 of the GDPR, Article 5.1.f) of the GDPR, and Article 32 of the GDPR, in accordance with the provisions of the aforementioned Article 58.2.d) of the GDPR, which states that each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”

Thus, the responsible entity may be required to align its actions with personal data protection regulations, to the extent expressed in the previous Legal Grounds.

In this act, the alleged infringement committed and the facts that could lead to this possible violation of data protection regulations are established, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully understands its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

72/77

However, in this case, regardless of the above, in accordance with the evidence available at this moment regarding the initiation of the sanctioning procedure, the resolution adopted may require GETECCU to adopt the following measures within THREE MONTHS from the date of effectiveness of the resolution concluding this procedure:

- To demonstrate the adoption of appropriate technical or organizational measures to ensure an adequate level of security for personal data, necessary to ensure compliance with the provisions of Article 5.1.f) of the GDPR.
- To demonstrate the execution of the corresponding data processing agreements with the hospital centers participating in the Project ***PROJECT.1, which comply with the requirements set forth in Article 28 of the GDPR.

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the resolution of the present sanctioning procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in Articles 83.5 and 83.6, which may lead to the initiation of a further administrative sanctioning procedure.

It is also reminded that neither the acknowledgment of the infringement committed nor, where applicable, the voluntary payment of the proposed amounts, exempts the obligation to adopt the necessary measures to cease the conduct or to correct the effects of the infringement committed and to demonstrate to this AEPD compliance with that obligation.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against the SPANISH WORKING GROUP ON CROHN'S DISEASE AND ULCERATIVE COLITIS (GETECCU), with NIF G07762669, for the alleged infringement of Article 5.1.f) and Article 28 of the GDPR, classified, respectively, in Article 83.5 and 83.4 of the GDPR.

SECOND: TO APPOINT R.R.R. as instructor and S.S.S. as secretary, indicating that they may be recused, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
73/77

THIRD: INCORPORATE into the file, for evidentiary purposes, the notification of the violation of personal data security, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the proceedings prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in art. 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be an administrative fine of 17,000.00 euros, without prejudice to what results from the instruction:

- For the alleged infringement of article 5.1.f) of the GDPR, classified in article 83.5 of the GDPR, an administrative fine of 10,000.00 euros.
- For the alleged infringement of article 28 of the GDPR, classified in article 83.4 of the GDPR, an administrative fine of 7,000.00 euros.

FIFTH: NOTIFY this agreement to GRUPO ESPAÑOL DE TRABAJO EN ENFERMEDAD DE CRON Y COLITIS ULCEROSA (GETECCU), with NIF G07762669, granting a hearing period of ten working days for it to submit allegations and present the evidence it deems appropriate. In its allegations, it must provide its NIF and the procedure number that appears in the heading of this document.

In accordance with the provisions of article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be established at 13,600.00 euros, resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be established at 13,600.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to formulate allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were to apply, the amount of the sanction would be established at 10,200.00 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the express withdrawal or renunciation of any action or appeal in the administrative route against the sanction.

For these purposes, in case of opting for any of them, it must send to the General Subdirectorate of Data Inspection an express communication of the withdrawal or renunciation of any action or appeal in the administrative route against the sanction indicating which of the two reductions it is opting for or if it is for both.

In the event that it chooses to proceed with the voluntary payment of any of the amounts indicated above (13,600.00 euros or 10,200.00 euros), it must do so by depositing it into account no. IBAN: ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which it is adhering.

Likewise, it must send the proof of deposit to the General Subdirectorate of Inspection along with the express communication of the withdrawal or renunciation of any action or appeal in the administrative route against the sanction to continue with the procedure in accordance with the amount deposited.

Finally, it is noted that according to the provisions of article 112.1 of the LPACAP, no administrative appeal is possible against this act.

1479-111124

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On January 16, 2025, GETECCU proceeded to pay the sanction in the amount of 10,200.00 euros making use of the two reductions provided in the initiation agreement transcribed above, which implies the acknowledgment of responsibility in relation to the facts referred to in the initiation agreement and its legal qualification.

THIRD: GETECCU has expressly renounced any action or appeal in the administrative route against the sanction.

FOURTH: In the initiation agreement transcribed above, it was indicated that, if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...".

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the initiation agreement is appropriate.

LEGAL GROUNDS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

75/77

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the Procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in Sanctioning Procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another non-pecuniary sanction but the imposition of the latter has been justified as inappropriate, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure and their effectiveness shall be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation."

III

Voluntary Payment and Acknowledgment of Responsibility

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified initiation agreement informed about the possibility of acknowledging responsibility and making the voluntary payment of the proposed sanction, which would entail two cumulative reductions of 20% each. With the application of these two reductions, the sanction would be established at 10,200.00 euros, and its payment would imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the notification of the aforementioned initiation agreement, the SPANISH WORKING GROUP ON CROHN'S DISEASE AND ULCERATIVE COLITIS (GETECCU) has proceeded to acknowledge responsibility and make the voluntary payment of the sanction, availing itself of the two reductions provided and expressly waiving any action or administrative appeal.

It should be noted that, in accordance with the provisions of the LPACAP, as well as the jurisprudence of the Supreme Court in this matter, the exercise of voluntary payment by the alleged responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their form of initiation. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and any others arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the initiation agreement transcribed in this resolution.

The sum of the aforementioned amounts yields a total of 17,000.00 euros.

After having proceeded with the prompt payment and acknowledgment of responsibility by the SPANISH WORKING GROUP ON CROHN'S DISEASE AND ULCERATIVE COLITIS (GETECCU), a reduction of 40% of the aforementioned total is applied, resulting in a final amount of 10,200.00 euros.

SECOND: TO DECLARE the termination of procedure EXP202310012, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: TO ORDER the SPANISH WORKING GROUP ON CROHN'S DISEASE AND ULCERATIVE COLITIS (GETECCU) to notify the Agency within 3 months from the date this resolution becomes final and enforceable, regarding the adoption of the measures described in the legal grounds of the initiation agreement transcribed in this resolution.

FOURTH: TO NOTIFY this resolution to the SPANISH WORKING GROUP ON CROHN'S DISEASE AND ULCERATIVE COLITIS (GETECCU).

FIFTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment and acknowledgment of responsibility to the withdrawal or renunciation of any action or administrative appeal, the present authority accepts the express waiver stated by the SPANISH WORKING GROUP ON CROHN'S DISEASE AND ULCERATIVE COLITIS (GETECCU).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

77/77

therefore, the filing of an optional appeal for reconsideration against this resolution is not admissible, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since no administrative appeal is admissible due to the express waiver, this resolution shall be final and fully enforceable from the date of its notification.

However, in accordance with the provisions of Article 90.3.a) of the LPACAP, the final resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data

Protection, submitting it through the Agency's Electronic Registry [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

1259-180225

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the Presidency and Deputy Presidency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es